



車載組込み開発のための暗号技術入門

Introduction to cryptographic technology for
in-vehicle embedded development

- 第1章 情報セキュリティのCIAと車載システムへの脅威
- 第2章 国際的な自動車サイバーセキュリティ標準化の取組み
- 第3章 車載ECUへ導入されるセキュリティ機能
- 第4章 暗号技術入門
- 第5章 ブロック暗号の利用モード
- 第6章 ハッシュ関数とMAC情報の改ざんを防ぐ技術
- 第7章 Root of trust(信頼の基点)

■第1章 情報セキュリティのCIAと車載システムへの脅威

【習得内容】

- ・情報セキュリティという用語の定義
- ・自動車セキュリティへの脅威
- ・車載ネットワークにMACを採用

■用語の定義

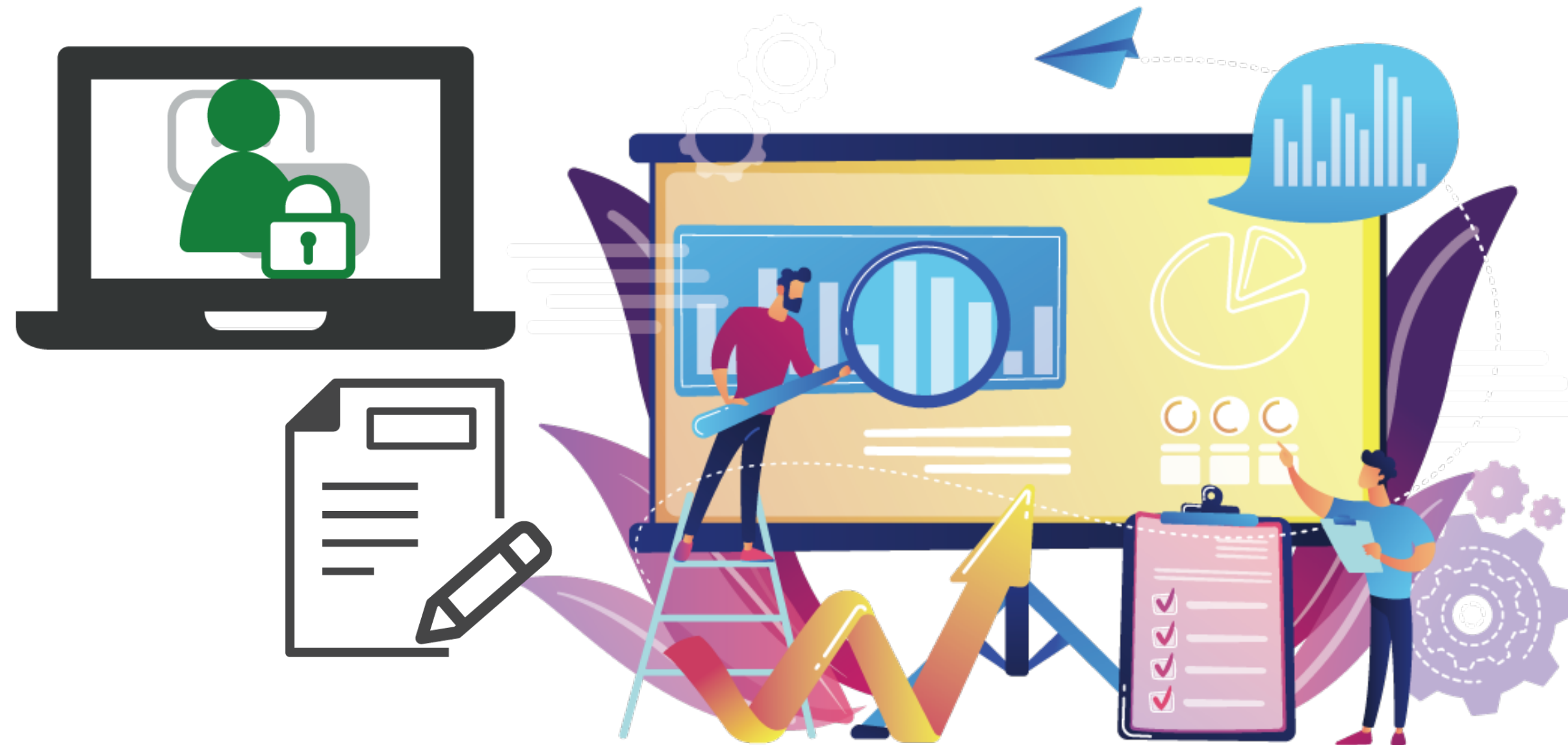
・情報セキュリティ(Information Security)

- 情報の機密性、完全性および可用性の維持 (JIS Q 27001)
- さらに真正性、責任追跡性、否認防止、信頼性などの特性維持を含める場合もあり (ISO/IEC27001)

—機密性(Confidentiality)

—完全性(Integrity)

—可用性(Availability)



■用語の定義

・情報セキュリティ(Information Security)

—機密性(Confidentiality)

許可されていない個人、エンティティ又はプロセスに対して、情報を使用不可または非公開にする特性

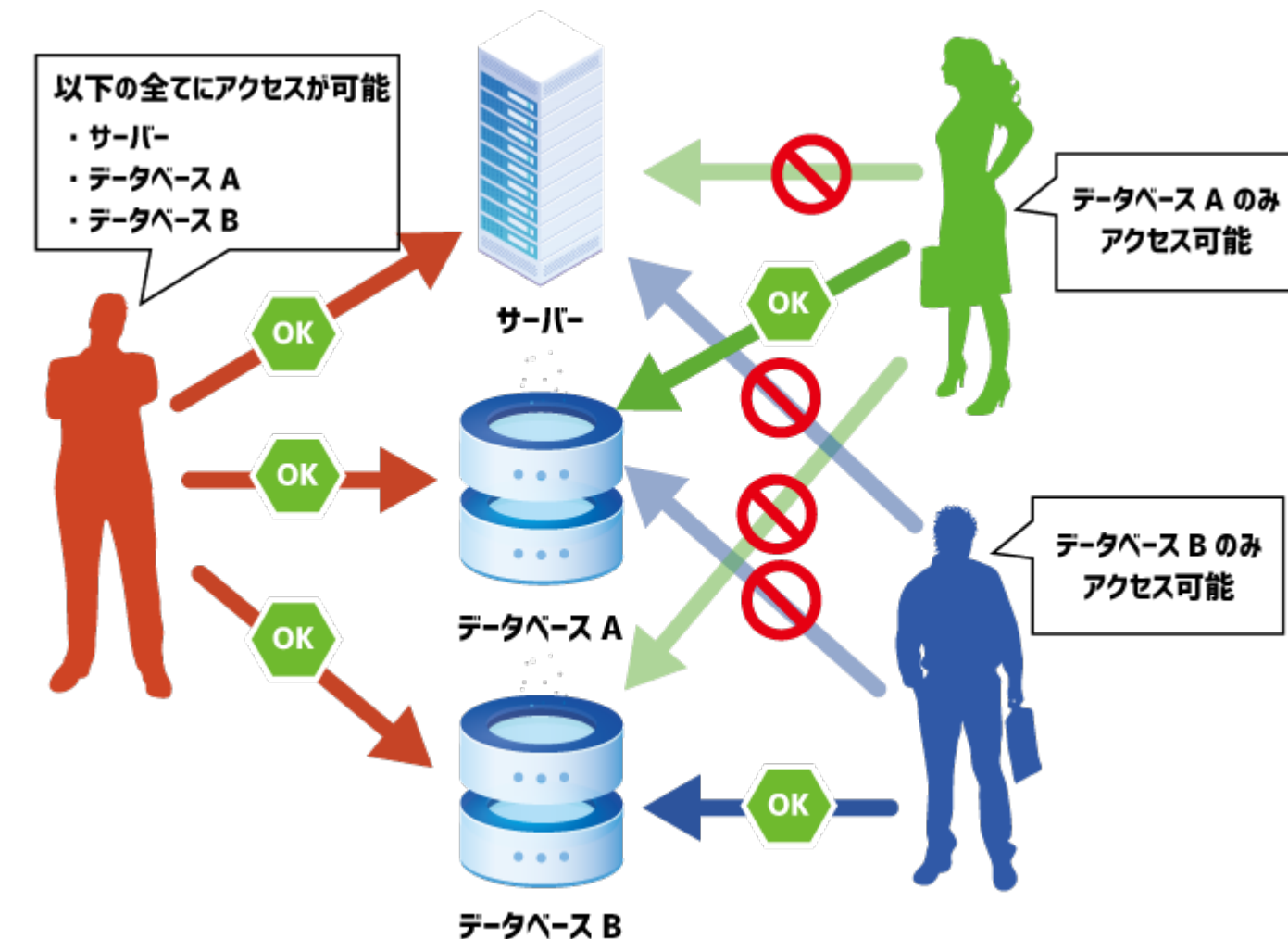
情報が漏れないこと、見てはいけない人が見れない様にする



パスワード認証、生体認証、暗号



パスワードの管理



アクセスコントロール

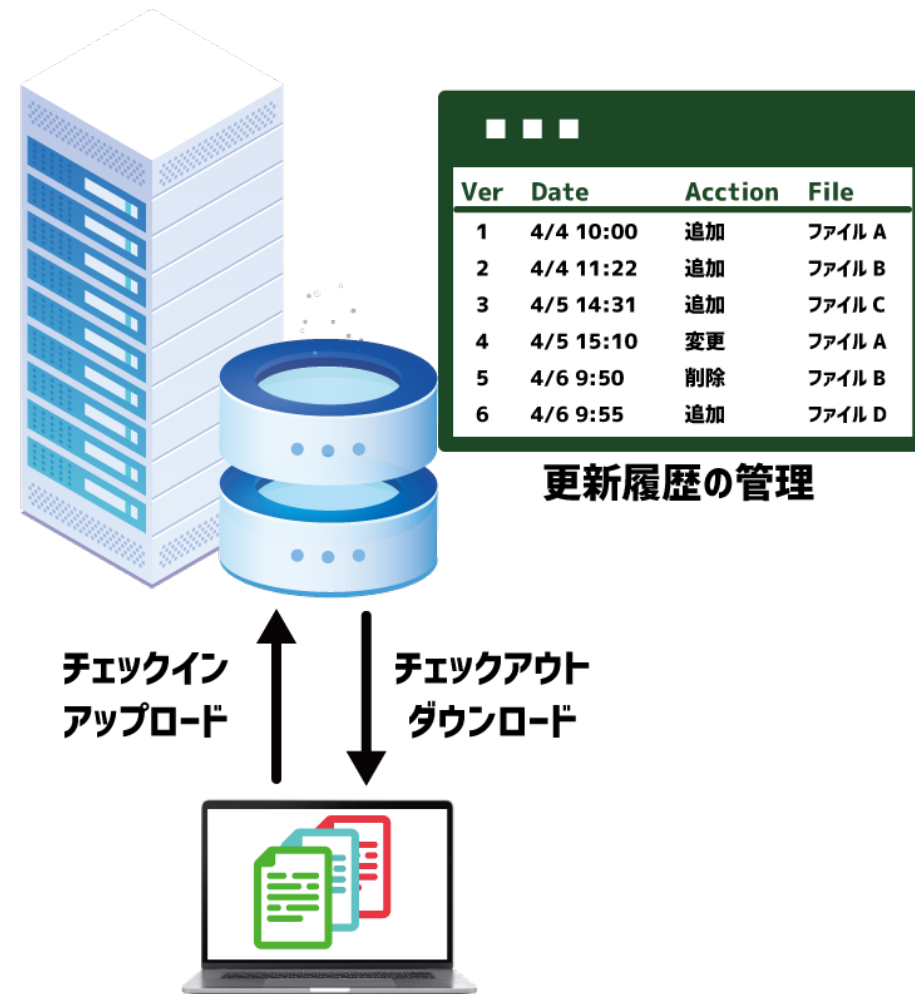
■用語の定義

・情報セキュリティ(Information Security)

—完全性(Integrity)

資産の正確さ及び完全さを保護する特性

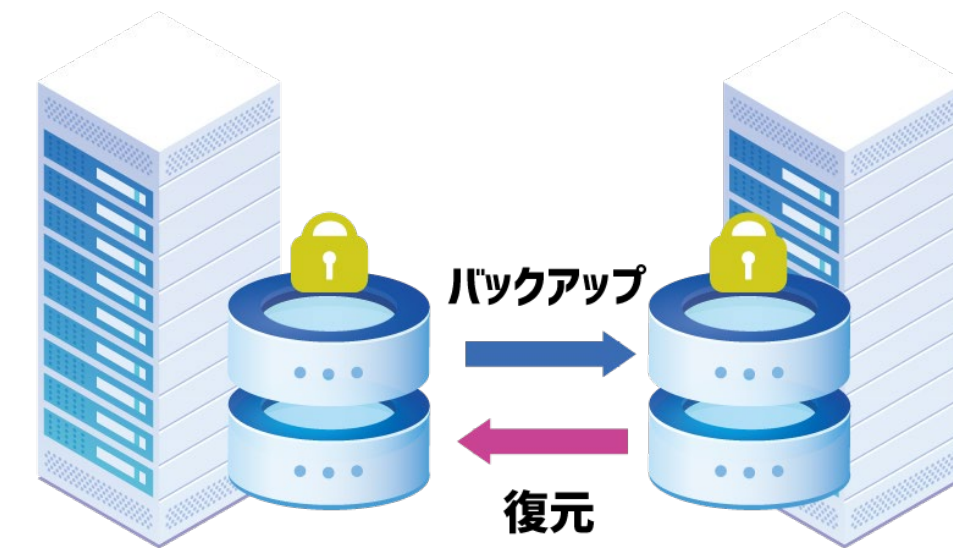
情報を保存した時点のままの状態が正確に維持されること



情報へのアクセス履歴や変更履歴を残す
バージョン管理



デジタル署名・暗号



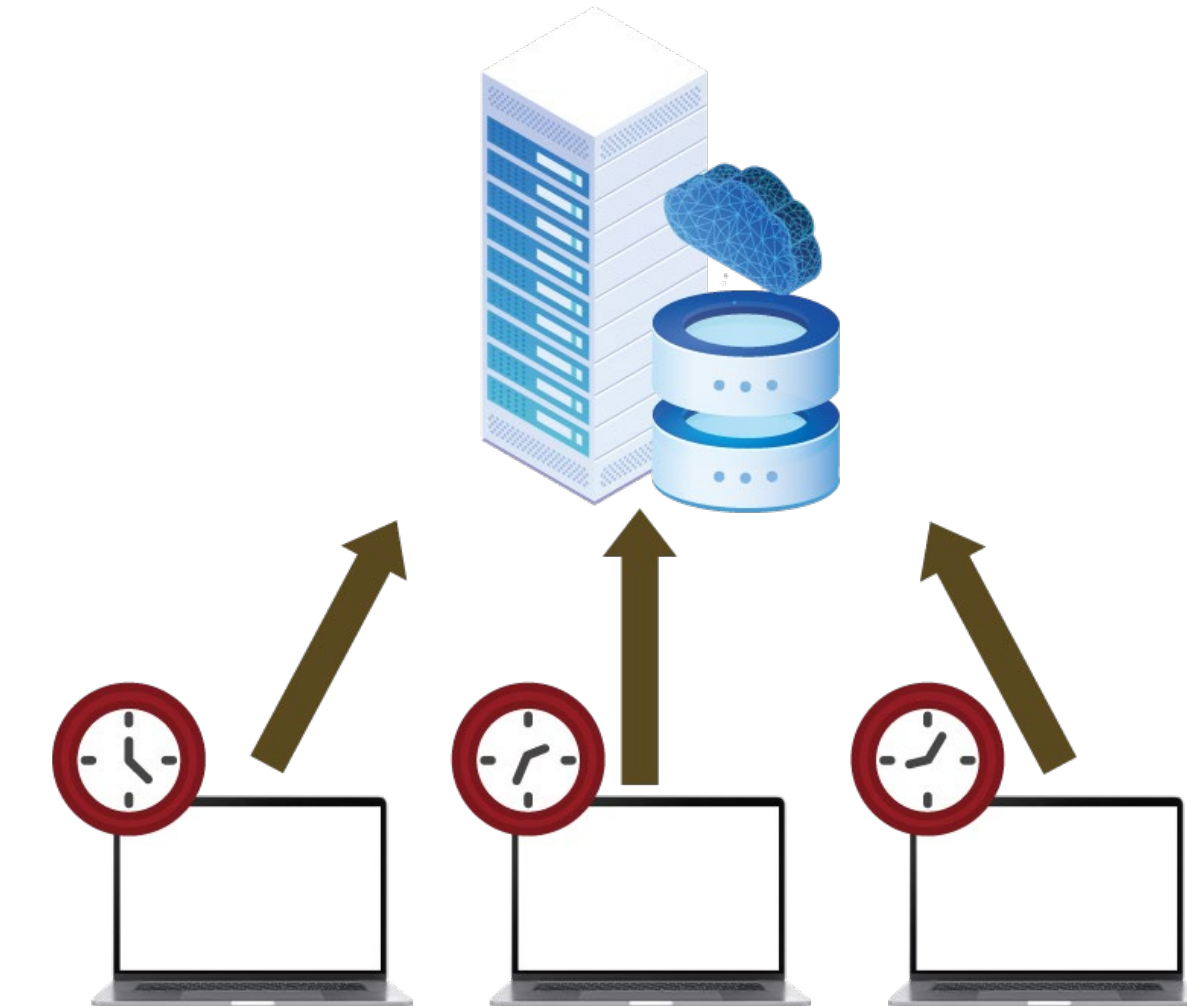
情報バックアップなど
データの保管に関するルール

■用語の定義

・情報セキュリティ(Information Security)

—可用性(Availability)

許可されたエンティティが要求した時に、アクセスおよび使用が可能である特性
情報資産が必要になった時に、いつでも利用できる状態であること

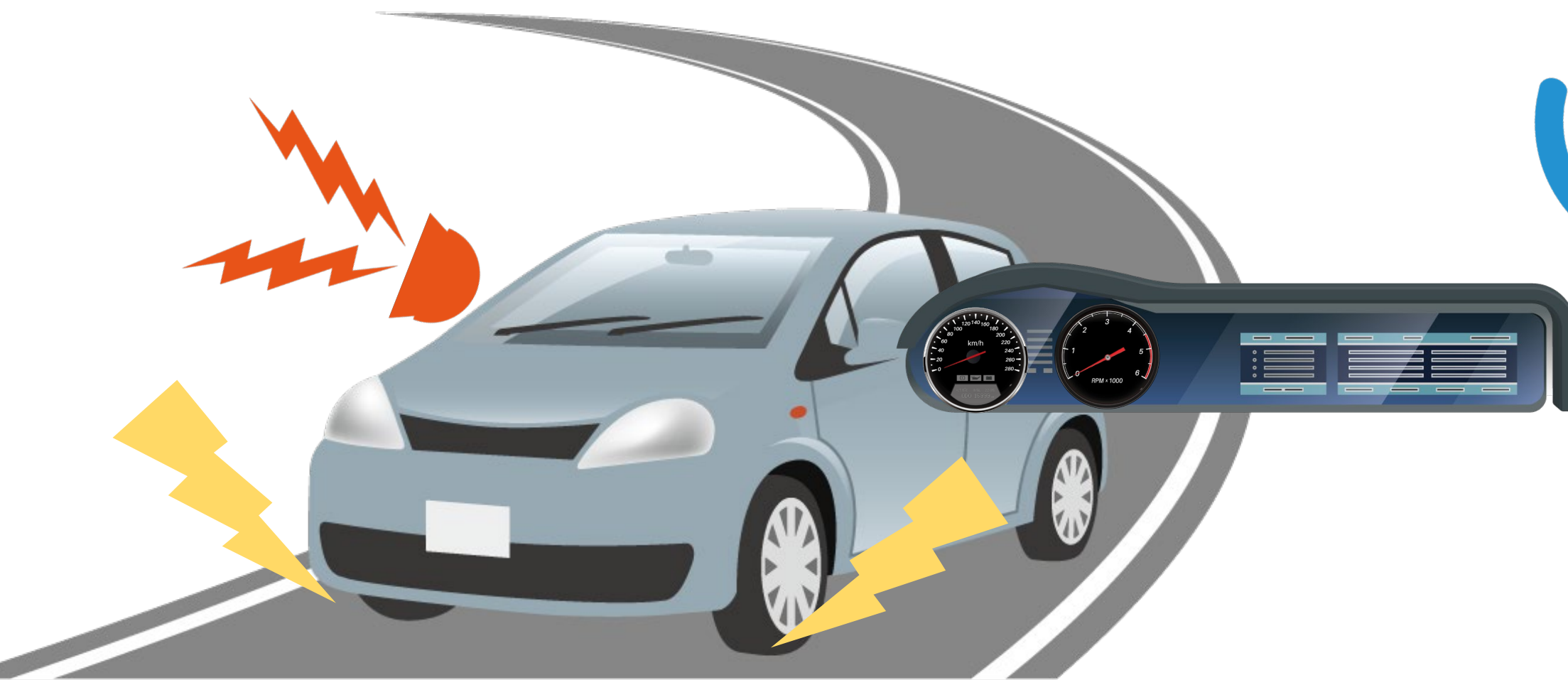


アクセスしたい時にアクセスできる

■自動車セキュリティへの脅威(1)

・ジープ・チェロキーへのリモートアタック実験(2015)

- 外部ネットワークからインフォテインメントシステムへ**侵入**
- 車載ECUのプログラムを**改ざん**
- 任意のCANメッセージを送信可能に



カーステレオの音量操作

エアコン操作

ラジオ局の変更

GPS情報から車を追跡

クラクション操作

走行中にブレーキ



■自動車セキュリティへの脅威(1)

・ジープ・チェロキーへのリモートアタック実験(2015)

【ハッキングができた原因】

—Wi-Fiのパスワードが簡単に突破されたため

マルチメディアシステムを最初に起動した時間
20yymmdd000000



製造年月
20yy年mm月製

情報入手



無数のパターンから
たったの700万通りに絞れたので、
あとは力業でも簡単に突破できる

クライスラーは140万台のリコール対応へ
サイバーセキュリティ対策として初めての大規模リコール

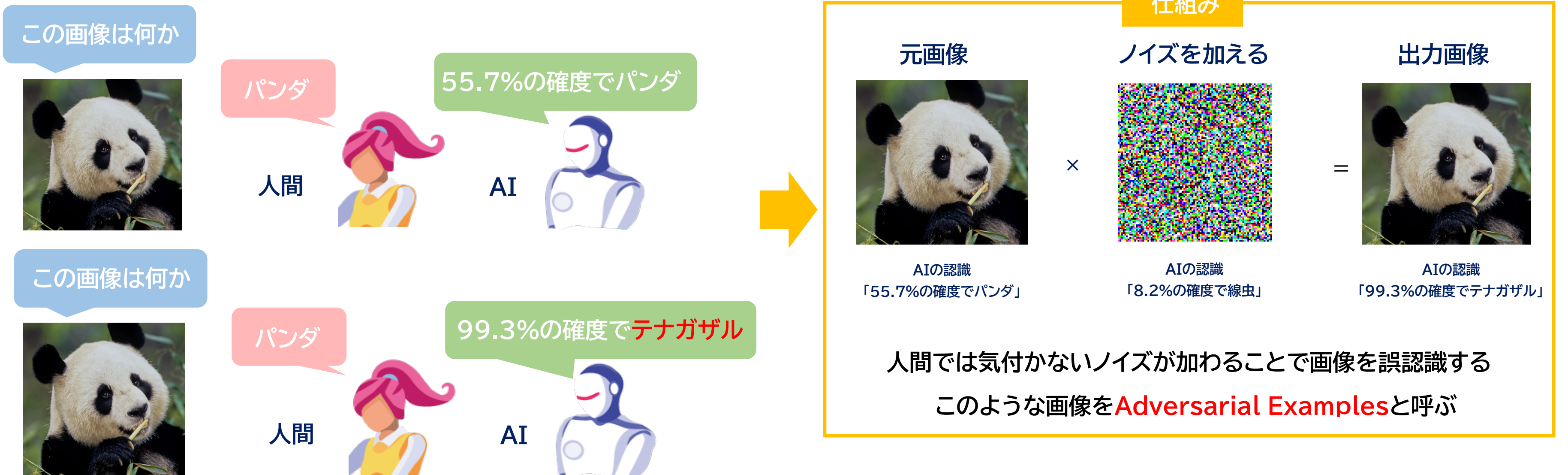
■自動車セキュリティへの脅威(2)

出展: Goodfellow, Ian J. and Shlens, Jonathon and Szegedy Christian.
Explaining and Harnessing Adversarial Examples. 20 may 2015, arXiv, 1412.6572v3.

・画像認識AIへの攻撃

—Adversarial Examples 攻撃

- ・人間では気づかないもしくは見過ごすノイズを加え、AI の誤認識を誘発させる

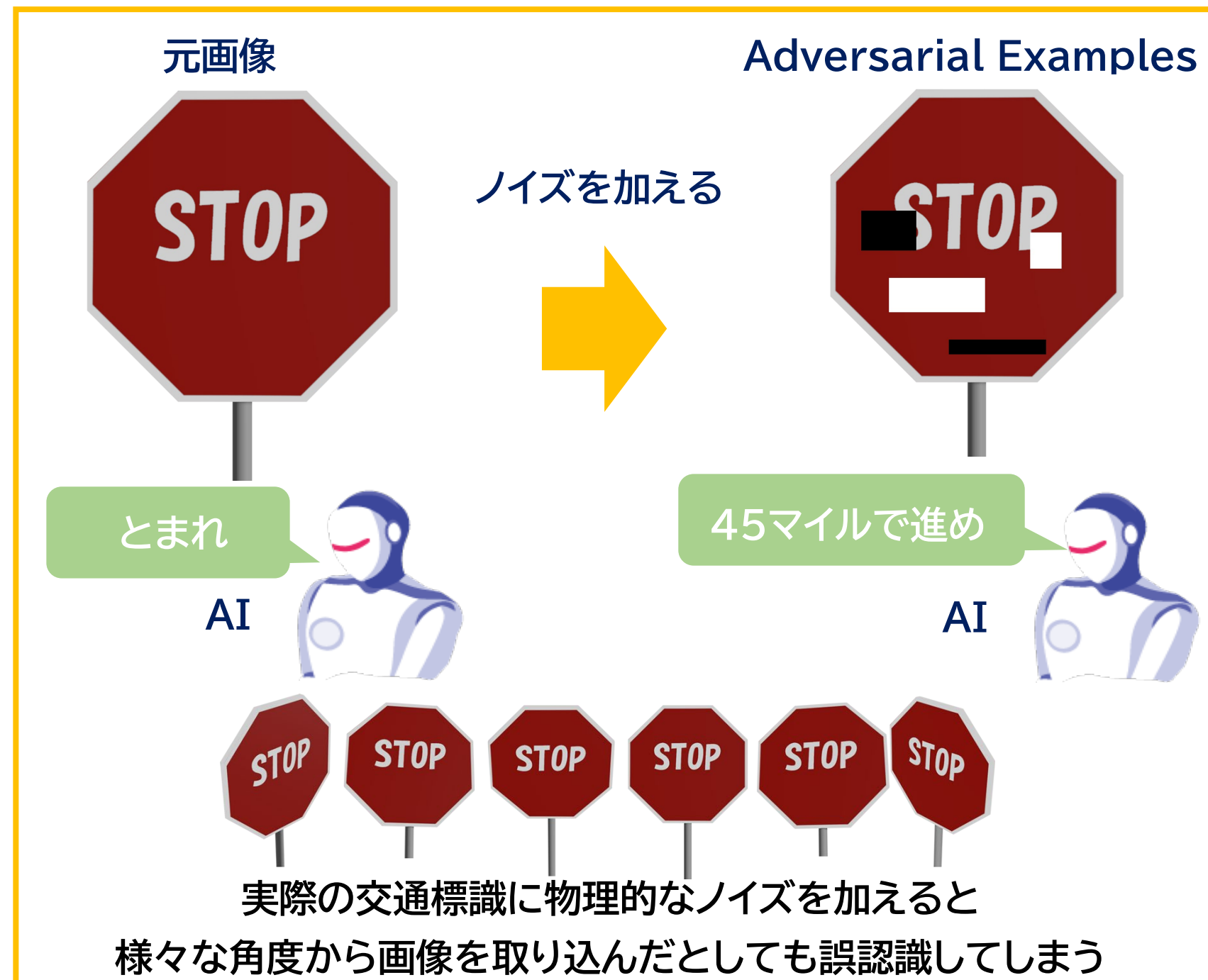


■自動車セキュリティへの脅威(2)

・画像認識AIへの攻撃

出展: Eykholt, Kevin and Evtimov, Ivan and Fernandes, Earlene and Li, Bo and Rahmati, Amir and Xiao, Chaowei and Prakash, Atul and Kohno, Tadayoshi and Song, Dawn. Robust Physical-World Attacks on Deep Learning Visual Classification. Proceedings of the IEEE Conference on Computer Vision and Pattern Recognition (CVPR). 2018.

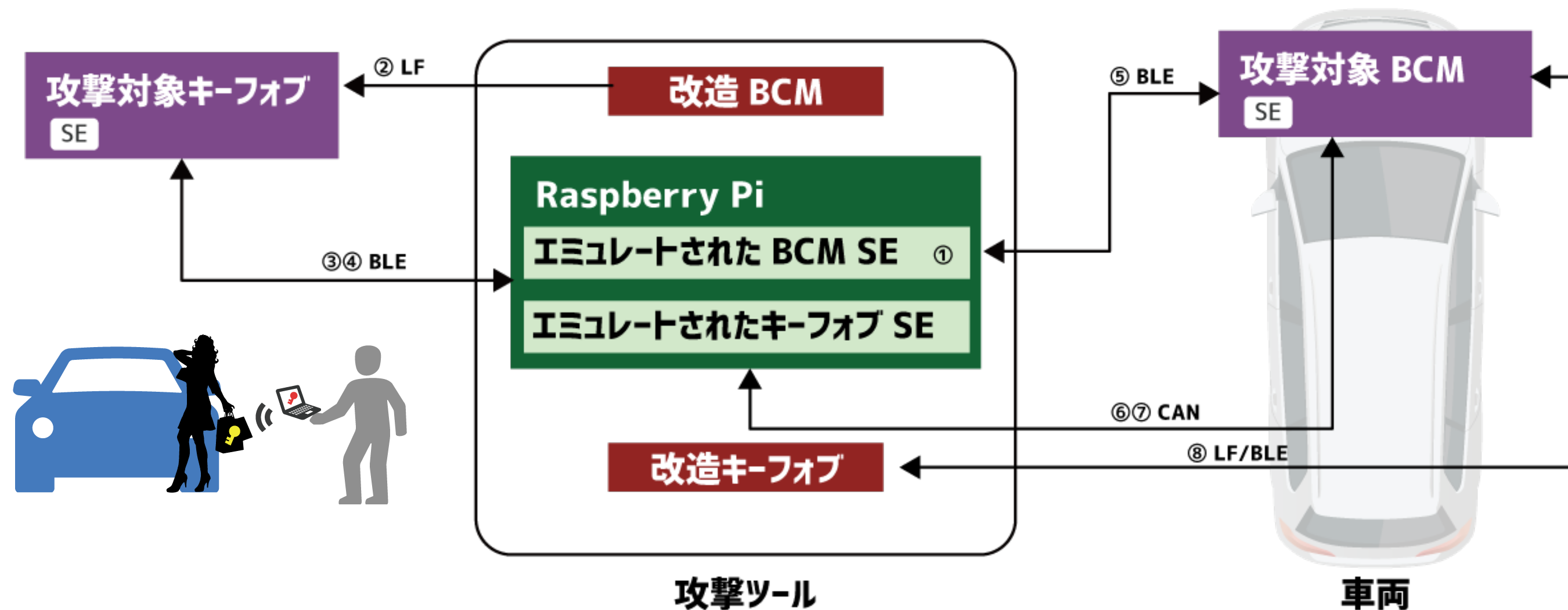
—自動車における画像認識システムへの脅威



■自動車セキュリティへの脅威(3)

・キーレスエントリーシステムへの攻撃

- BLEを介して、キーフォブのソフトウェアを改ざん、ロック解除用のコマンドを取得し、ドアをアンロック
- 車両に侵入し、OBD2コネクタから物理的に車両ネットワークに侵入
- 新しいキーフォブとペアリングし、車両を持ち去る

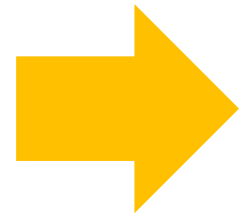


SE :Secure Element
BCM :Body Control Module
LF :Low Frequency
BLE :Bluetooth Low Energy
OBD2:車両診断ポート

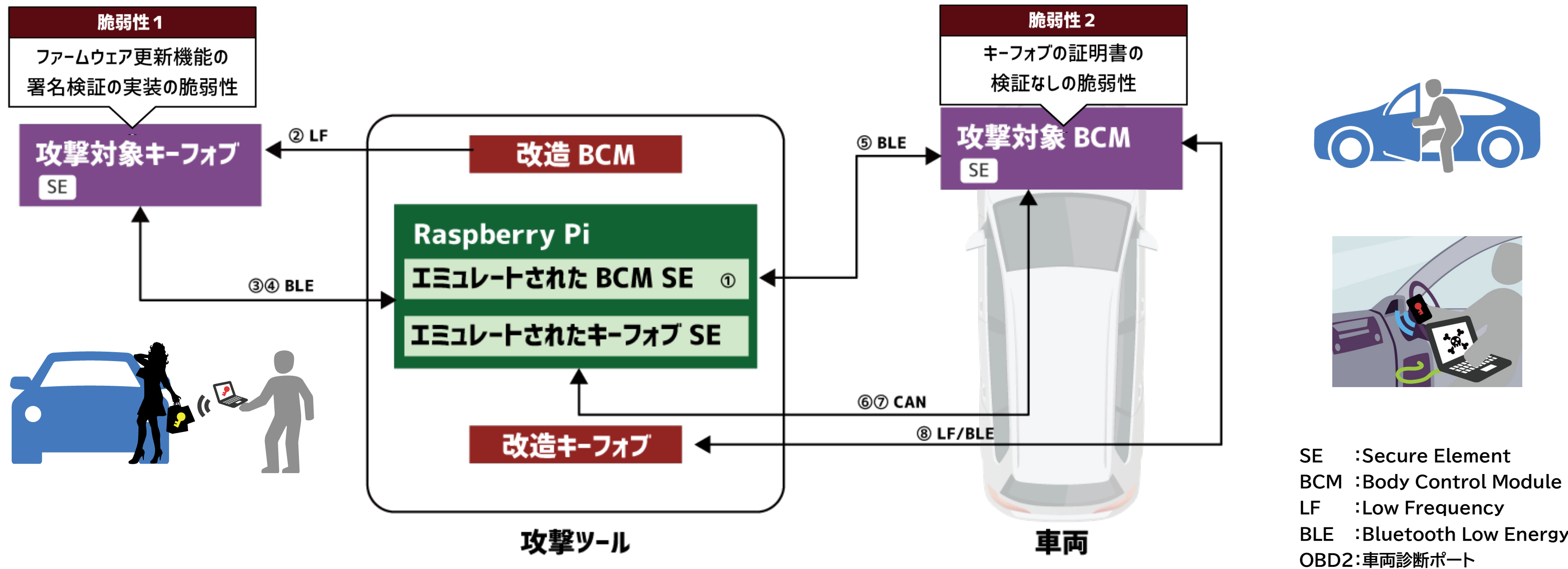
■自動車セキュリティへの脅威(3)

・キーレスエントリーシステムへの攻撃

- 更新ファームウェアに署名が不要だった
- 車両がキーフォブの証明書を検証しない



即時修正パッチを当てて対処するアップデートを実施
問題の発覚後の対応フローを確立することが重要



■自動車の在り方の変化と各社のサイバーセキュリティ対策

・自動車の在り方の変化

- 従来の自動車ネットワークは完全なクローズドネットワークであったため、データの暗号化や外部からの侵入を考慮していなかった
- 自動車の高性能化に伴い、WiFiやBluetoothといった車外との通信機機能が備わったことにより、外部からの侵入経路と車載通信のなりすましによる自動車制御の脅威が現実味となった



■自動車の在り方の変化と各社のサイバーセキュリティ対策

- ・トヨタ、Hondaは暗号によるメッセージ認証(CMAC)を導入
 - AESによるメッセージ改ざんへの対策
- ・鍵管理を行う新しい部署を設置
 - 車の部品間の通信に使う暗号鍵を安全に生成し、管理する
 - 部品メーカーへの管理体制の導入を要求

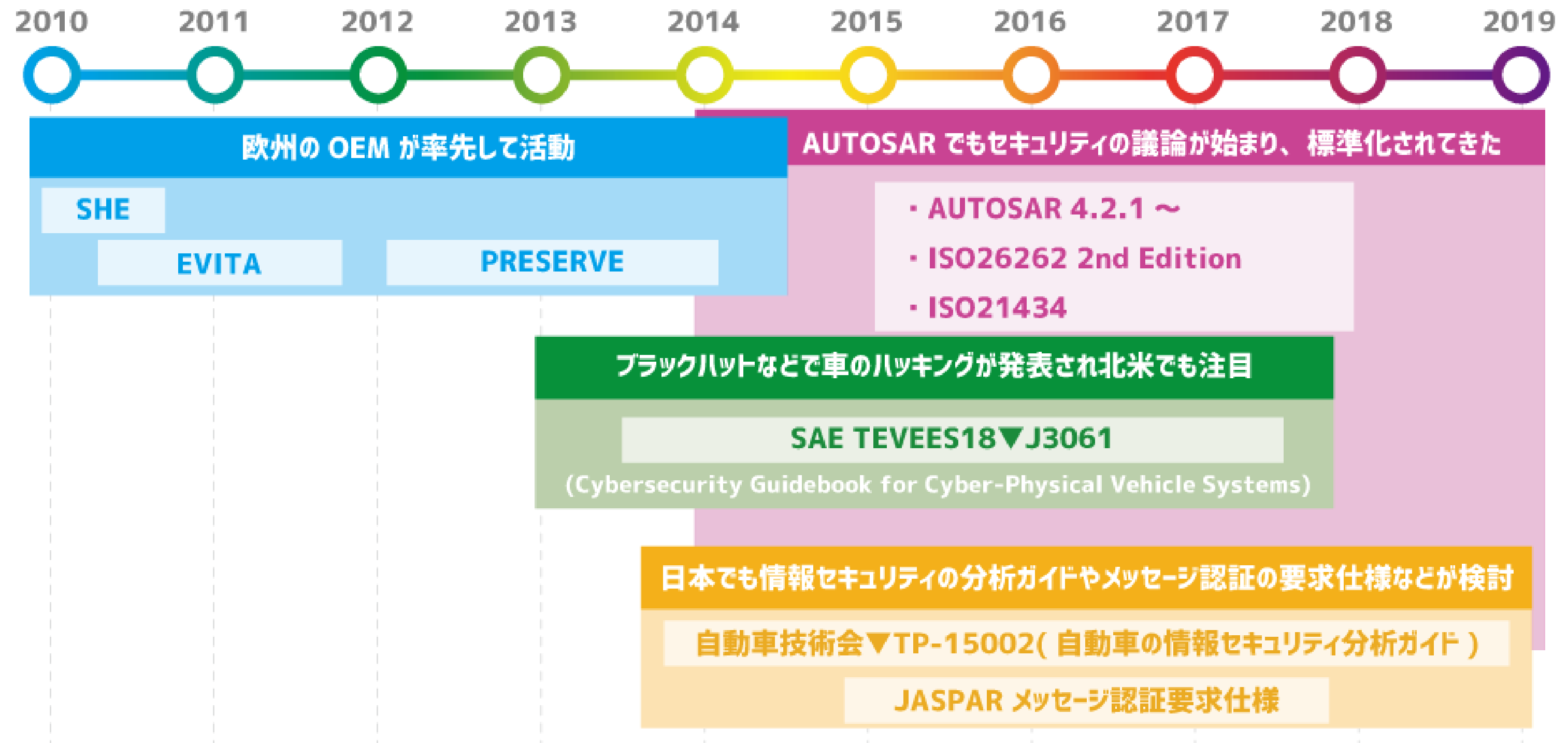


■第2章 国際的な自動車サイバーセキュリティ標準化の取組み

【習得内容】

- ・国際的な自動車サイバーセキュリティ標準化への取組みの概要
- ・WP29(自動車基準調和フォーラム)の活動/動向
- ・ISO/SAE 21434概要

■国際的な自動車サイバーセキュリティ標準化の取組み



■欧州の取組み

- ・標準化活動は欧州が先行で開始

- HIS(Hersteller Initiative Software)

- ・ドイツの自動車メーカー5社による利益集団、当初の目的は車載ソフトウェアの設計や品質保証の手法を標準化・活用すること

- EVITA(E-safety Vehicle Intrusion Protected Applications)

- ・自動車をサイバー攻撃から保護する目的で車載LANのセキュリティを保護する通信手順と実行処理基盤を研究開発

- ・ECUに必要なとなるセキュリティ機能のハードウェア規格を以下で策定

- SHE(Secure Hardware Extension)

- HSM(Hardware Security Module)

セキュリティに関する処理を制御CPUから独立させることで、外部アタックから守る仕組み

■北米の取組み

・北米の自動車セキュリティ標準化活動

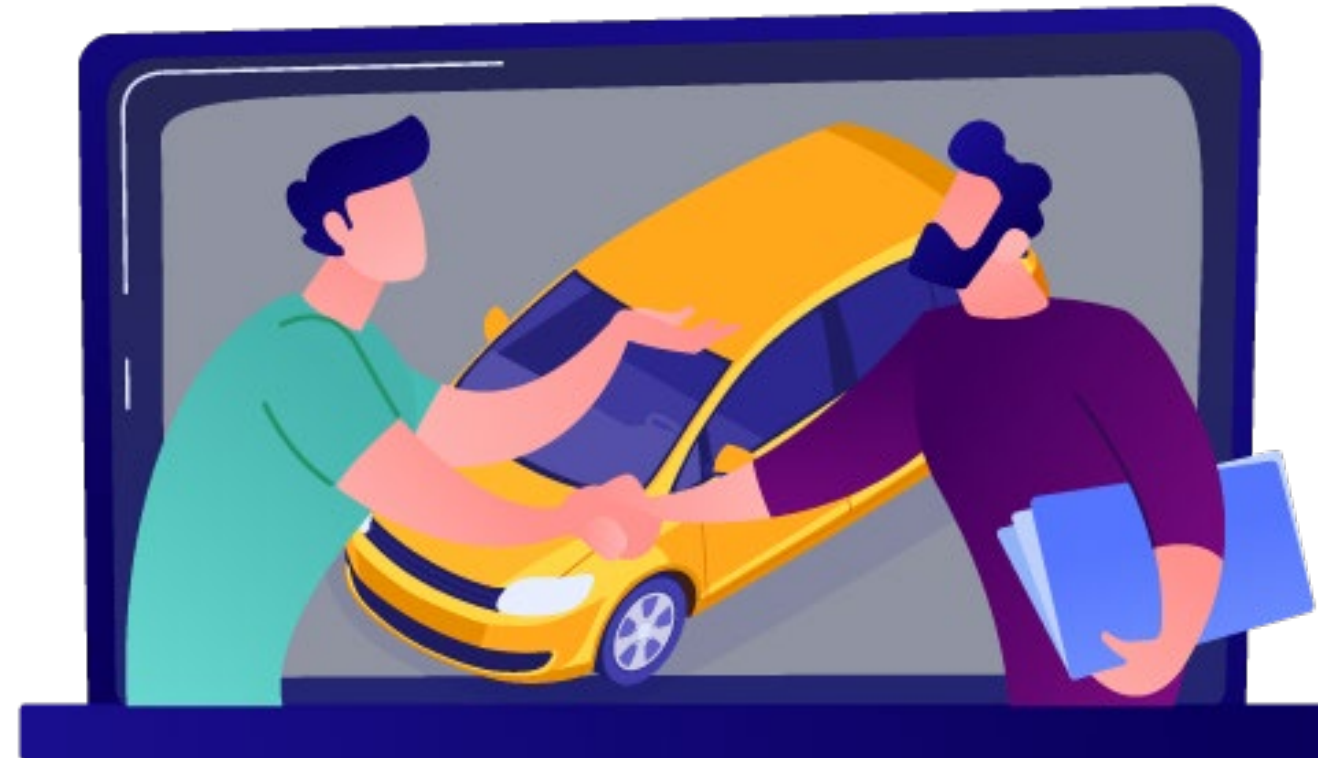
—SAE(Society of Automotive Engineers)により

J3061(Cybersecurity Guidebook for Cyber-Physical Vehicle Sysetem)を規定

自動車のサイバー攻撃に対するガイドラインやセキュリティ開発プロセスを規定

・自動車メーカーが提供した実車両をハッキングするチャレンジコンテストの開催

露呈した侵入経路やハッキング技術を自動車メーカーが取込み実践的なセキュリティ対策



■日本の取組み

・日本の標準化活動

—JASPAR(Japan Automotive Software Platform and Architecture)

メッセージ認証要求仕様策定など自動車セキュリティの議論が行われている

—自動車技術会から「JASO TP-15002:自動車の情報セキュリティ分析ガイド」が発行

自動車システムの脅威分析、リスクアセスメントなどセキュリティ分析の手法を定義

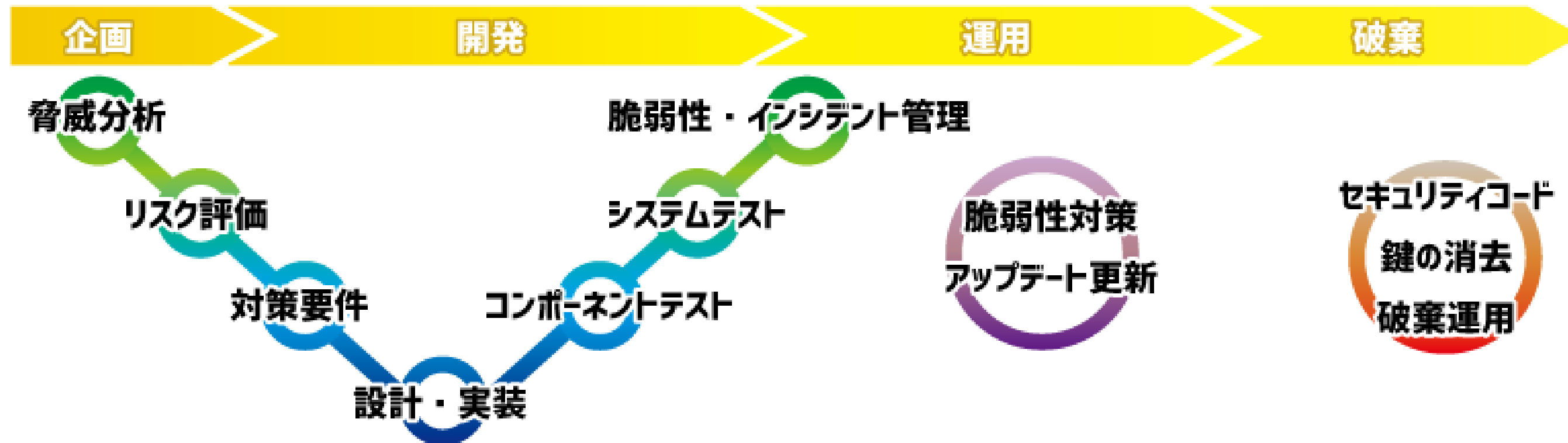


■WP29(自動車基準調和フォーラム)

・2つのセキュリティ関連ガイドラインを提示(2018)

—Proposal for a Recommendation on Cyber Security(PRCS)

—Draft Recommendation on Software Updates of the Task Force on Cyber Security and Over-the-air issues



車両のライフサイクル全体にわたるサイバーセキュリティ対策を原則としている

車両メーカーだけでなく、下請け業者、サプライヤ、潜在的な第三者を含む

全ての組織でシステムのセキュリティを強化するために協力する必要がある

■WP29(自動車基準調和フォーラム)

・2つのセキュリティ関連ガイドラインを提示(2018)

—Proposal for a Recommendation on Cyber Security(PRCS)

・サイバーセキュリティの原則を10項目あげているが

自動車のサイバーセキュリティの原則、脅威、緩和策などの指針や観点を示すのみ

《ECU開発に関わる5項目》

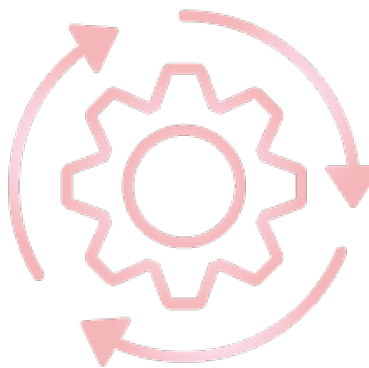
—ソフトウェアのセキュリティは、その存続期間を通じて管理する必要がある

—データの保存と送信は安全かつ管理できる必要がある

—自動車メーカーは、テスト手順でセキュリティ機能を評価する必要がある

—車両はサイバー攻撃に対して回復力があるように設計する必要がある

—車両はサイバー攻撃を検出し、適切に対応する機能を備えて設計する必要がある



■WP29(自動車基準調和フォーラム)

・2つのセキュリティ関連ガイドラインを提示(2018)

—Proposal for a Recommendation on Cyber Security(PRCS)

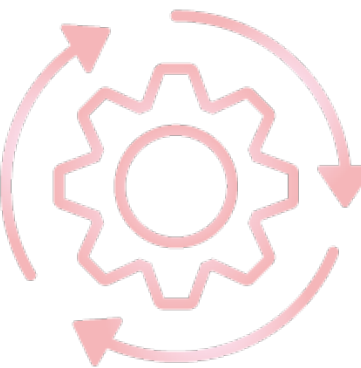
- ・サイバーセキュリティの原則を10項目あげているが
自動車のサイバーセキュリティの原則、脅威、緩和策などの指針や観点を示すのみ

《課題》

ECUや車載ネットワーク通信を守るため、メッセージ認証のような通信技術や
ECUソフトウェアをアップデートするためのリプログラミング機能が必須となっていく

自動車のサイバーセキュリティとソフトウェアアップデートに関する国際基準(UN規則)を採択

国際基準を満たす体制であることを示す必要や、
サプライチェーンや自動車の使用期間の全体像を見た対応が求められる。



■WP29(自動車基準調和フォーラム)

・自動車サイバーセキュリティに関する2つのレギュレーションが合意(2020)

—UN-R155

自動車のサイバーセキュリティ及びその管理システムに関する要件
(サイバーセキュリティマネジメントシステム)

—UN-R156

ソフトウェアアップデートおよびその管理システムに関する要件



いずれも車両型式認証を取得する際の追加要件を規定しており、全58ヶ国が批准する見通し

- ・欧州では新型車両の認証は2022年7月以降、継続生産車両は2024年以降適合が必須
- ・日本では無線ソフトウェアアップデート対応車両は、欧州と同様のタイミングで適合が必須
非対応車両では新型車で2024年1月以降、継続生産車では2026年5月以降適合が必須

■ISO/SAE 21434

- ・自動車サイバーセキュリティに関する国際規格

ISO/SAE 21434として2021年8月にIS版が発行

- リスク管理手法、開発プロセス、生産・運用・破棄、サイバーセキュリティ管理など
車両開発から廃止までのライフサイクル全般にわたるサイバーセキュリティ要件を定めたもの
- 対象は、車両、車両のシステム、部品、ソフトウェアの他
ネットワークにより車両へつながる外部デバイス(カーナビ、ETC車載機など)も含まれる
- UN-R155に対応する規格となっている

■サイバーセキュリティマネジメント

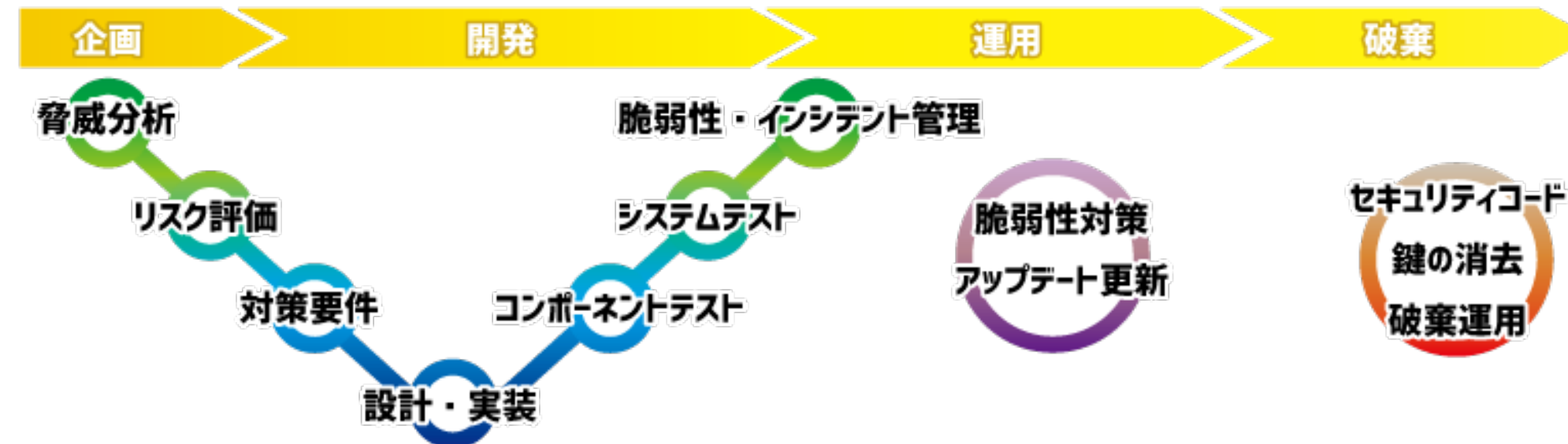
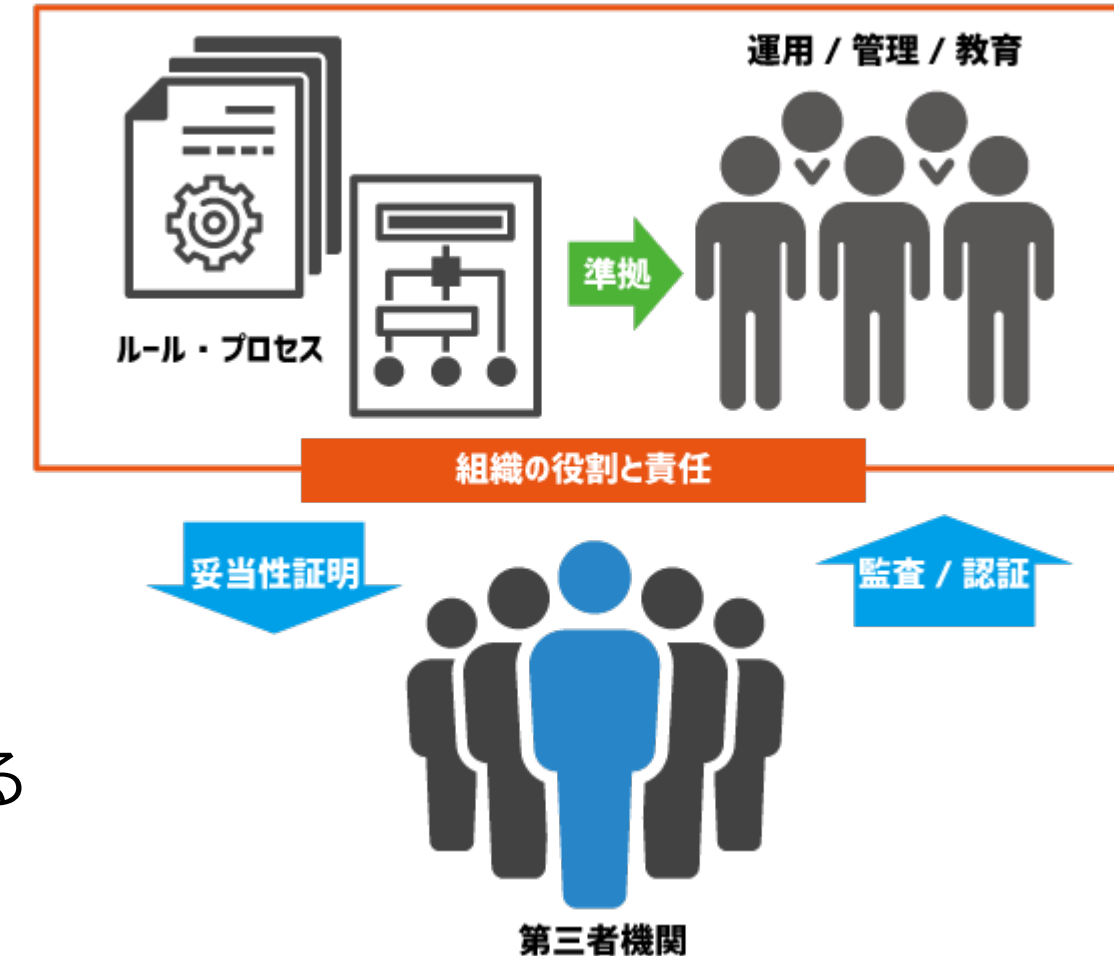
・ISO/SAE21434はサイバーセキュリティマネジメントとして以下2つが要求される

ー組織のサイバーセキュリティ管理

- ・ISO/SAE21434に準拠したルールとプロセスを構築
- ・実際にプロセスを運用するための組織の構築
- ・組織がプロセスを準拠しているか、第三者からの監査が求められる

ープロジェクトのサイバーセキュリティ管理

- ・セキュリティを担保するための計画を立て、その計画に沿って開発を進める必要がある
- ・ハードウェア/ソフトウェア両面でのセキュリティ確保が求められ、特有の管理策が必要



■第3章 車載ECUへ導入されるセキュリティ機能

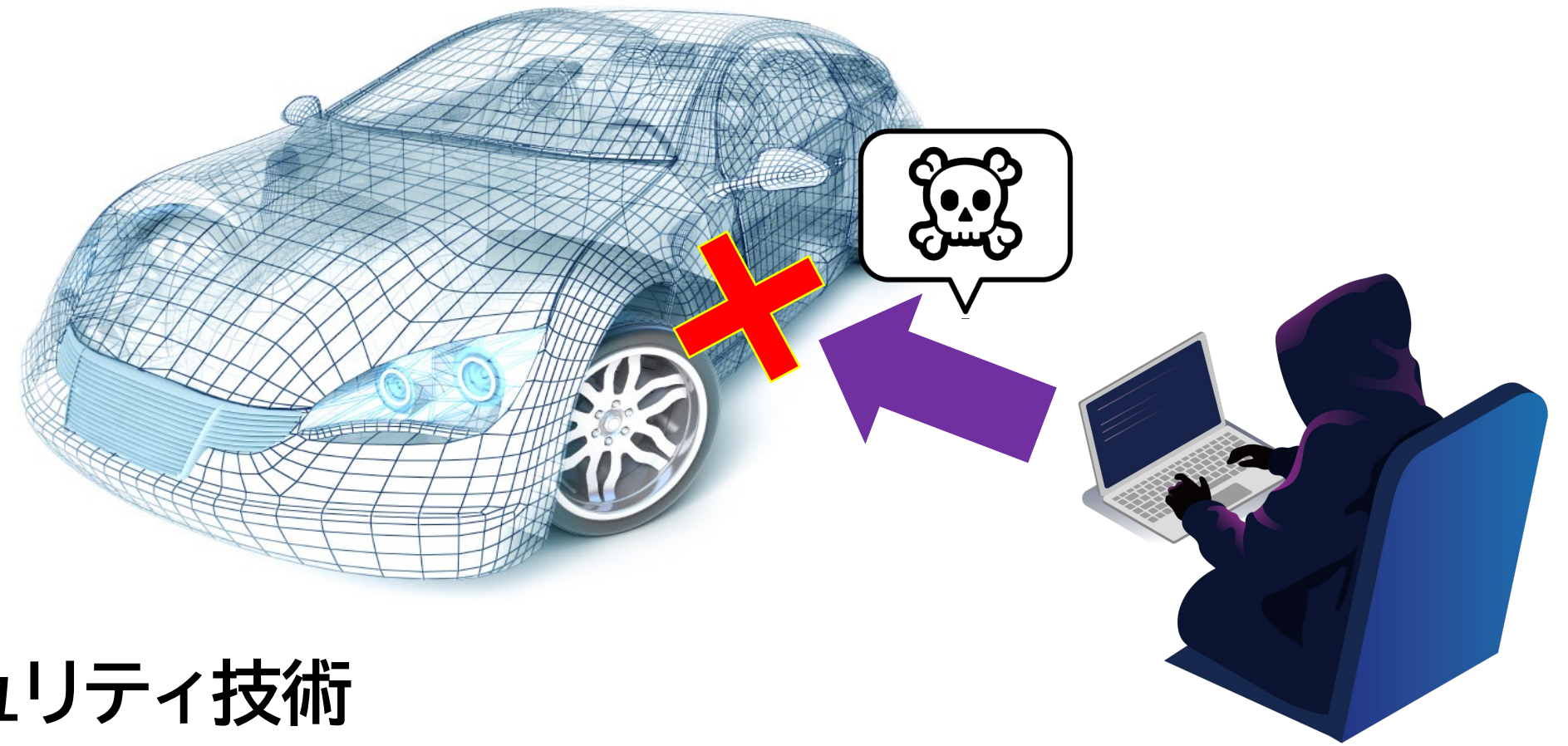
【習得内容】

- ・車載ECUへ導入されるセキュリティ機能の概要
- ・メッセージ認証機能
- ・ハードウェアセキュリティモジュール

■自動車制御を守るセキュリティ

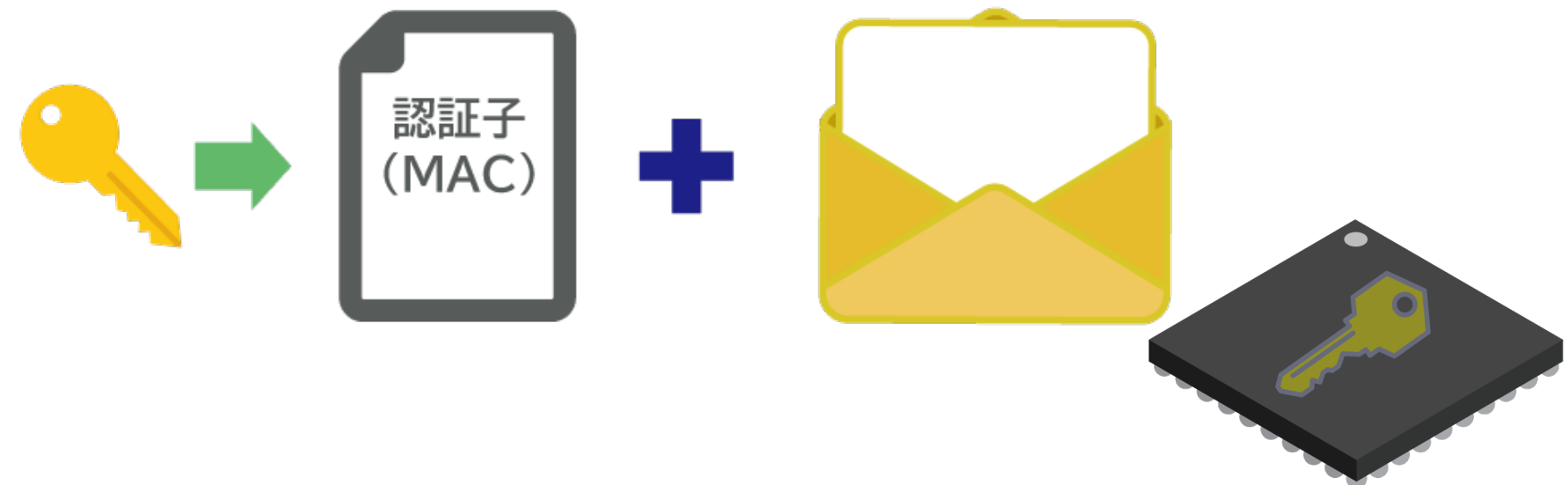
・ハッキング事例を防ぐための対策

- 不正な侵入を防ぐ
- ECUのプログラムを改ざんさせない
- ネットワークへ不正なデータを送受信させない



・車載ECUに導入されようとしているセキュリティ技術

- メッセージ認証
- ハードウェアセキュリティモジュール



■メッセージ認証

・ハッキング事例を防ぐための対策

- 車載ネットワーク通信の不正データやなりすましデータを検出・防止する仕組み
- 送信用データに認証子データを付与して受信側で認証子データが一致した時にのみ有効判定とする
- メッセージ認証子のことをMAC(Message Authentication Code)と呼ぶ



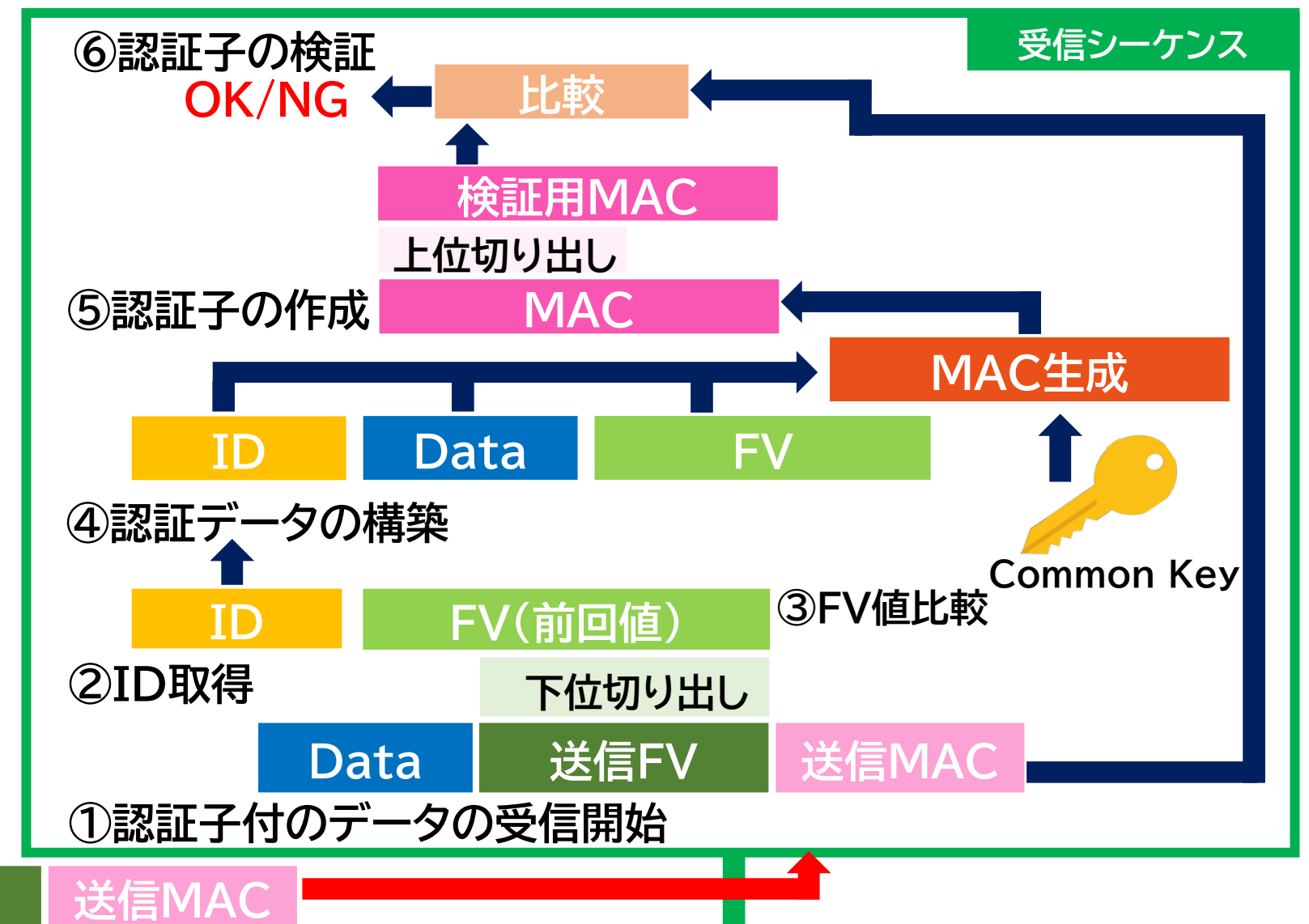
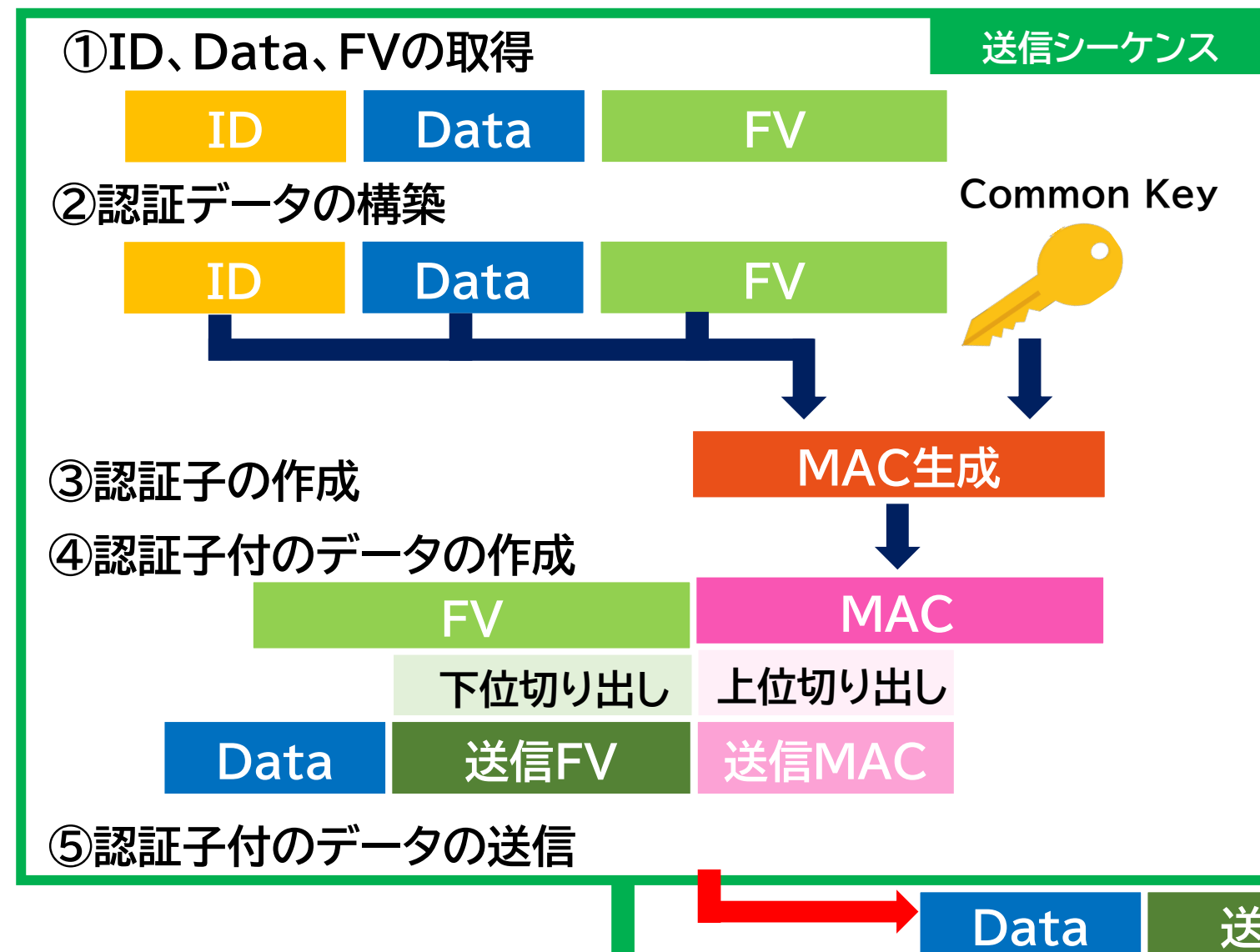
AUTOSAR SecOC

•AUTOSAR Secure Onboard Communication

—AES-CMACアルゴリズム

—再送攻撃(replay attack)を防ぐためのカウンター(Freshness Value)

—受信ECUは不正なMACを持ったメッセージを破棄



■ハードウェアセキュリティモジュール(HSM)

・マイコンやSoC等のデバイスに内蔵されるセキュリティ機能の専用モジュール

—暗号鍵/復号鍵の耐攻撃性

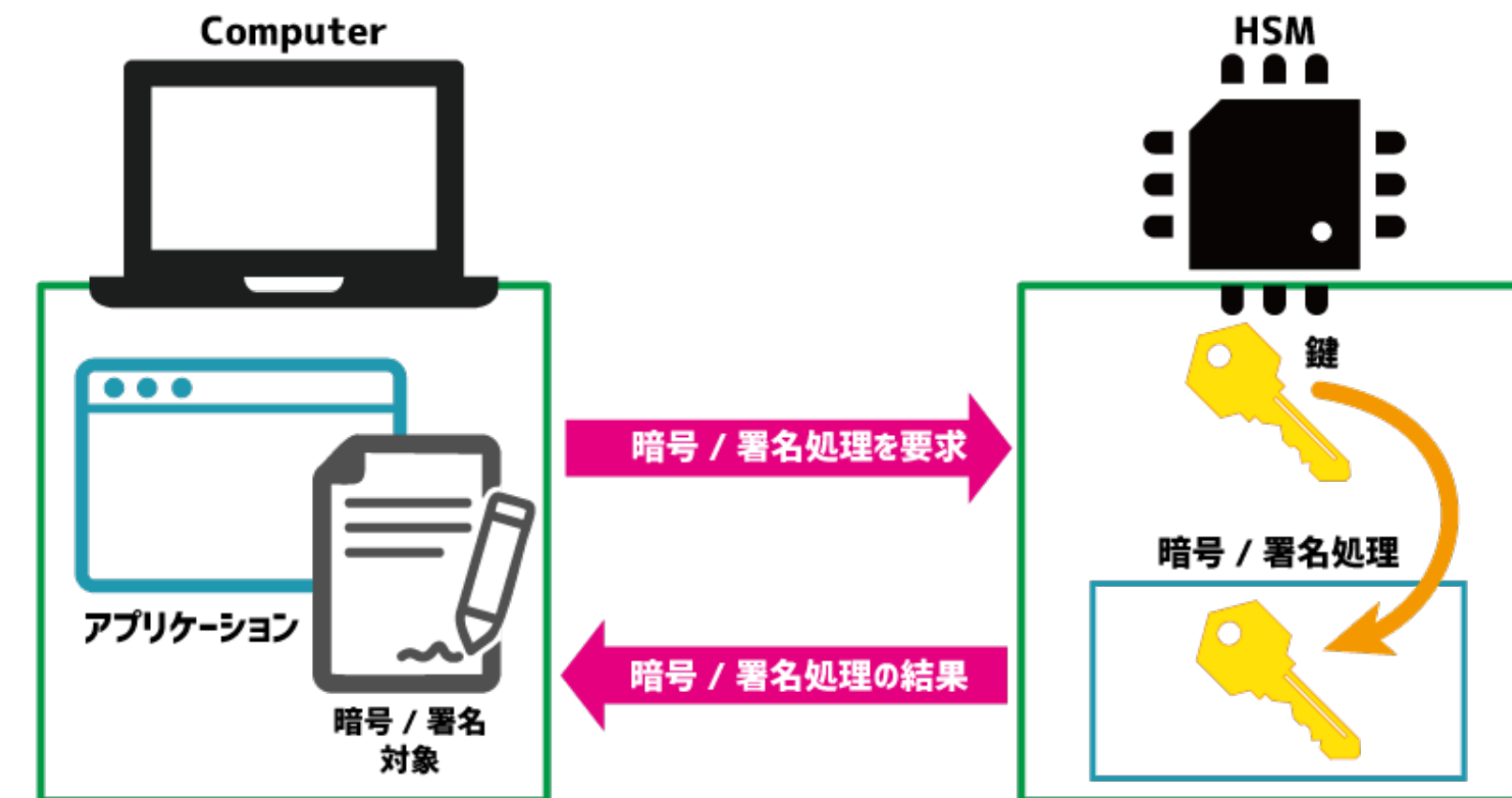
・物理的に盗難されない限り、外部からの攻撃では鍵が漏洩しない

—高速暗号処理

・専用チップによる暗号化・復号処理、電子署名演算

—鍵の集約中央管理

・アプリケーションと分離させることで別権限での鍵管理を実現



鍵管理や認証子のための暗号生成や乱数発生などの重要機能を

ハードウェア的に独立したセキュアゾーンで実施することで、外部からの不正操作を防止

■ハードウェアセキュリティモジュール(HSM)

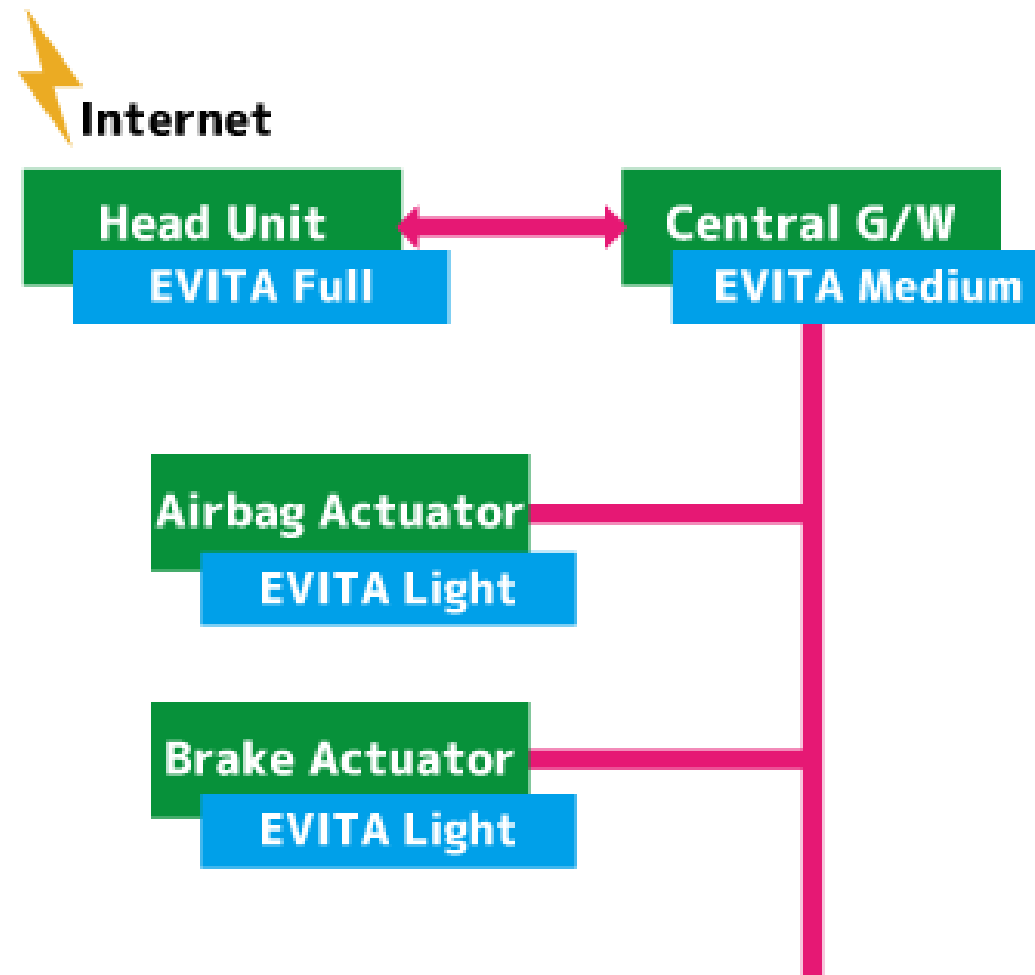
・欧州のHISによるSHE(Secure Hardware Extension)

HIS: Hersteller Initiative Software

EVITA: E-safetyVehicle Intrusion Protected Applications

・EVITAプロジェクトによるHSM(Hardware Security Module)

—セキュリティレベルに応じて3段階のHSMを規定



—EVITA Full

- ・楕円曲線暗号(ECC)アクセラレータやHash、AESアクセラレータを搭載
- ・車車間や路車間を繋ぐV2X通信をするECUへの適応を想定

—EVITA Medium

- ・セキュリティ用CPUを搭載、クリティカル以外の用途でソフトウェア処理が可能
- ・エンジンECUやパワトレ系ECU、セントラルG/Wなど鍵管理をするECUへの適応を想定

—EVITA Light

- ・AESアクセラレータを搭載、主にメッセージ認証やCMAC生成・検証を行う
- ・端末のOnboard CommunicationをするセンサやアクチュエータECUへの適応を想定

■第4章 暗号技術入門

【習得内容】

- ・現代の暗号技術の基本
- ・代表的な暗号技術の概要

■現代の暗号

- ・現代の暗号は、我々の財産・プライバシーを守るために様々なデジタル機器で利用されている

スマートカード



モバイル機器



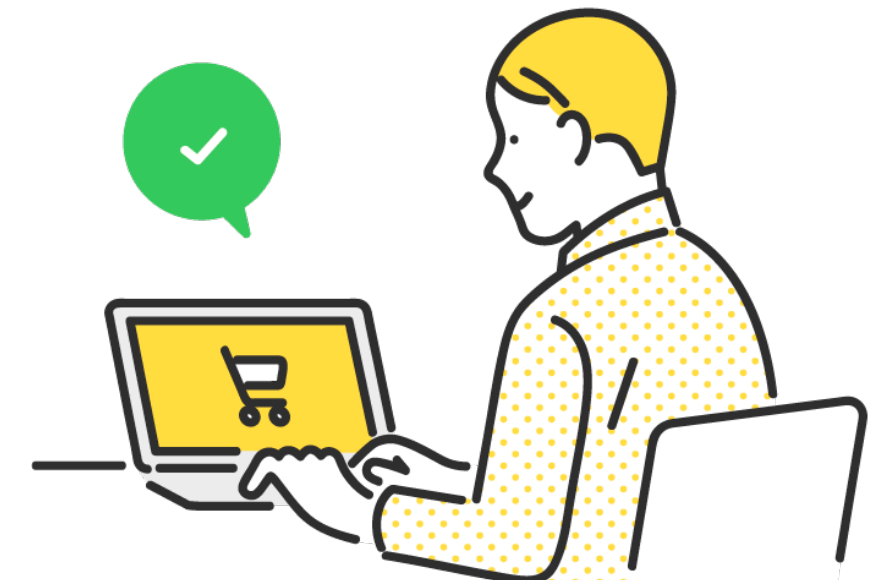
WiFi通信



デジタルコンテンツ



ネットショッピング



■暗号(Cryptography)

- ・第三者から秘密を守る技術
- ・秘密の情報である鍵(key)を用いて、文章の変換(暗号化)を行い、その変換規則を知っている者だけが文章を復元(復号)できるアルゴリズム
- ・過去、その用途は軍事に特化しており、暗号技術は軍事機密だった

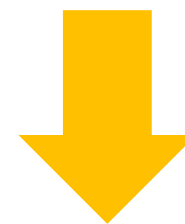


最も古い暗号「スキュタレー暗号」



鍵は巻きつける棒の太さ

ぶるうたすおまえもか



1文字ずらす

べれえちせかみおやき

ジュリアス・シーザーが使ったと言われる暗号
「シーザー暗号」
文章の各文字をあいうえお順に何文字かずらす



鍵はずらす文字数



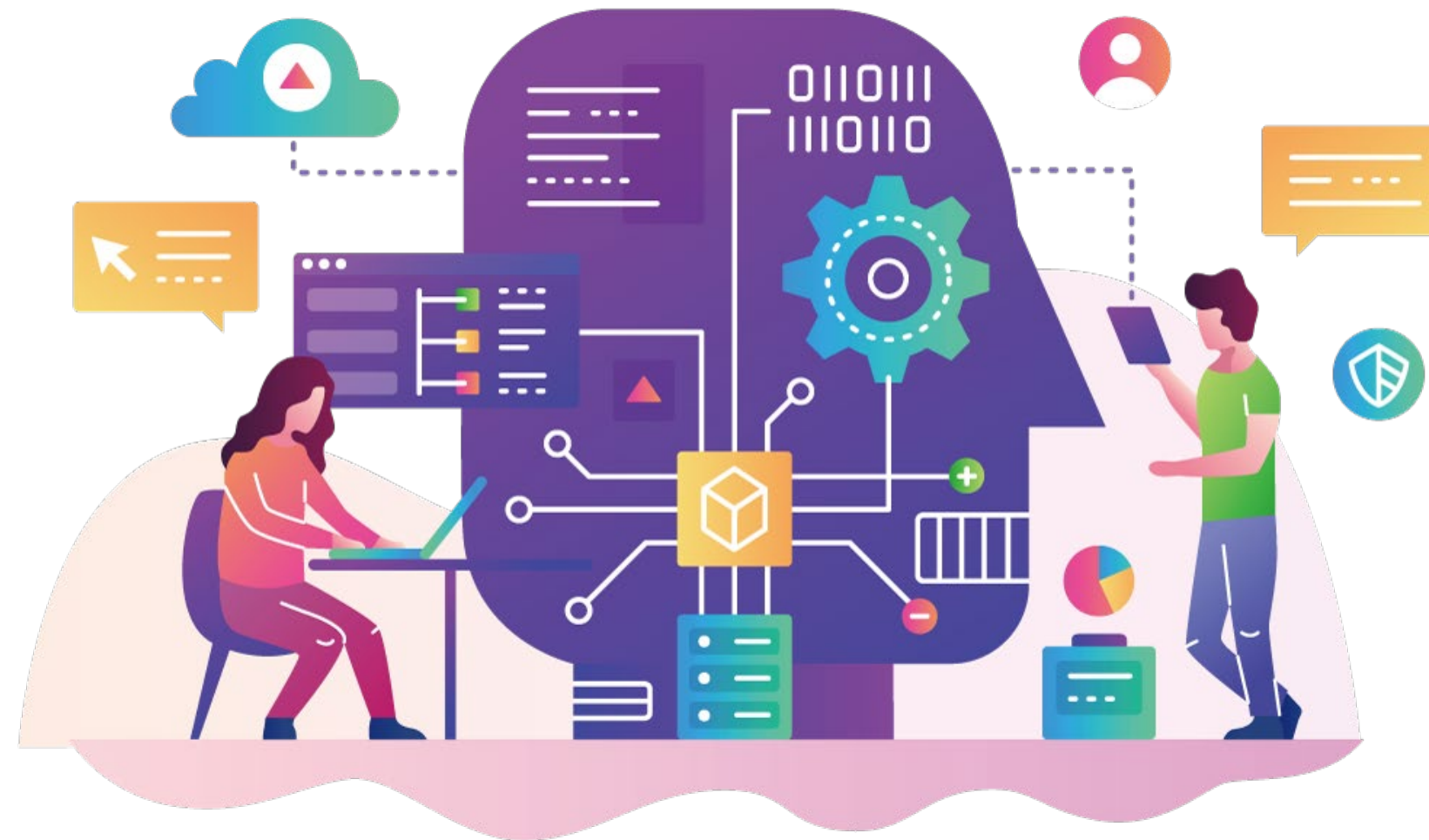
第二次世界大戦中に使われた
ドイツの機械式暗号機「エニグマ」



鍵はロータの設定の組合せ

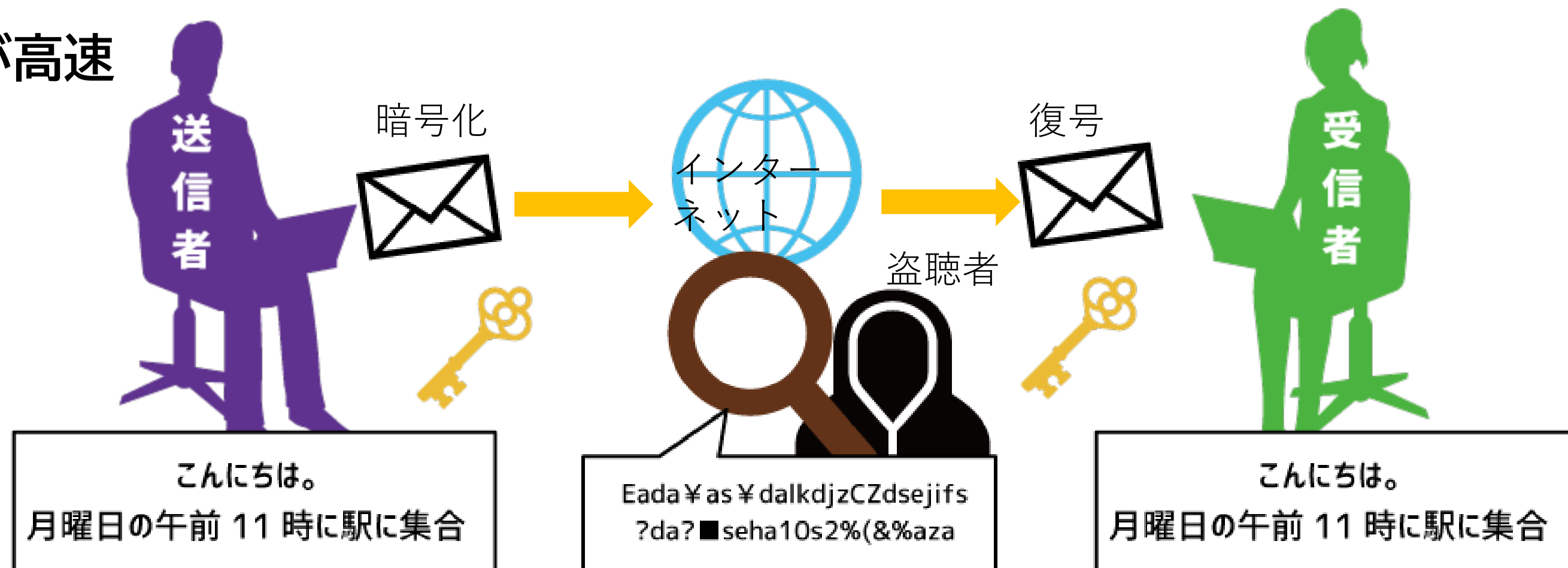
■現代の暗号の要件(ケルクホフスの原理)

- 秘密鍵を除く全ての情報が敵に知られても、安全でなければならない(歴史からの教訓)
 - 秘密鍵(だけ)を安全に守る
 - 「付箋にパスワードを書いてディスプレイに貼る」に暗号は無力(ソーシャル・エンジニアリング)
- 手続き(アルゴリズム)はオープンに
- 現代の暗号は「**鍵のみが秘密である**」前提で研究者からその安全性のチェックを受けている



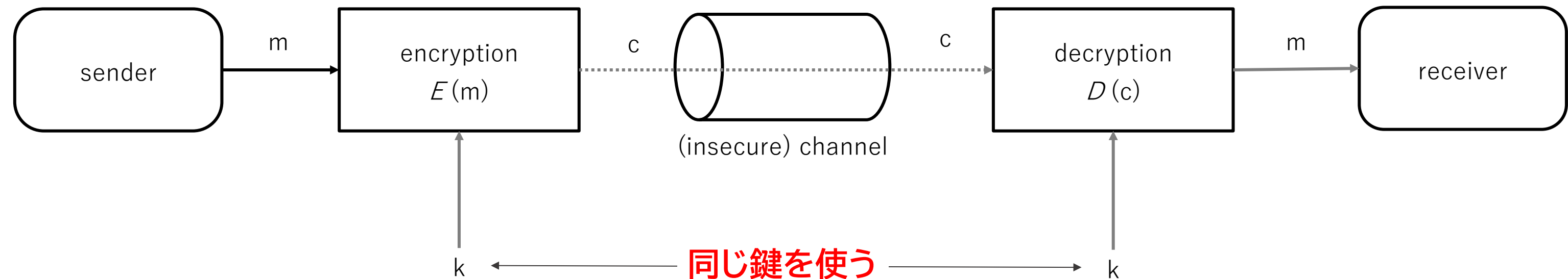
■共通鍵暗号(Common key Cryptography)

- 暗号化のときに使う鍵と復号の時に使う鍵が同じで共通鍵(Common Key)と呼ばれる
- 対称鍵暗号(Symmetric Cryptography)とも呼ばれる
- 元の文(message)を平文(plain text)、暗号化された文を暗号文(cipher text)と呼ぶ
- 暗号文は意味のない文字列になる
- 共通鍵暗号の代表的なアルゴリズム: AES、DES、Camellia
- 暗号化・復号が高速



■共通鍵暗号(Common key Cryptography)

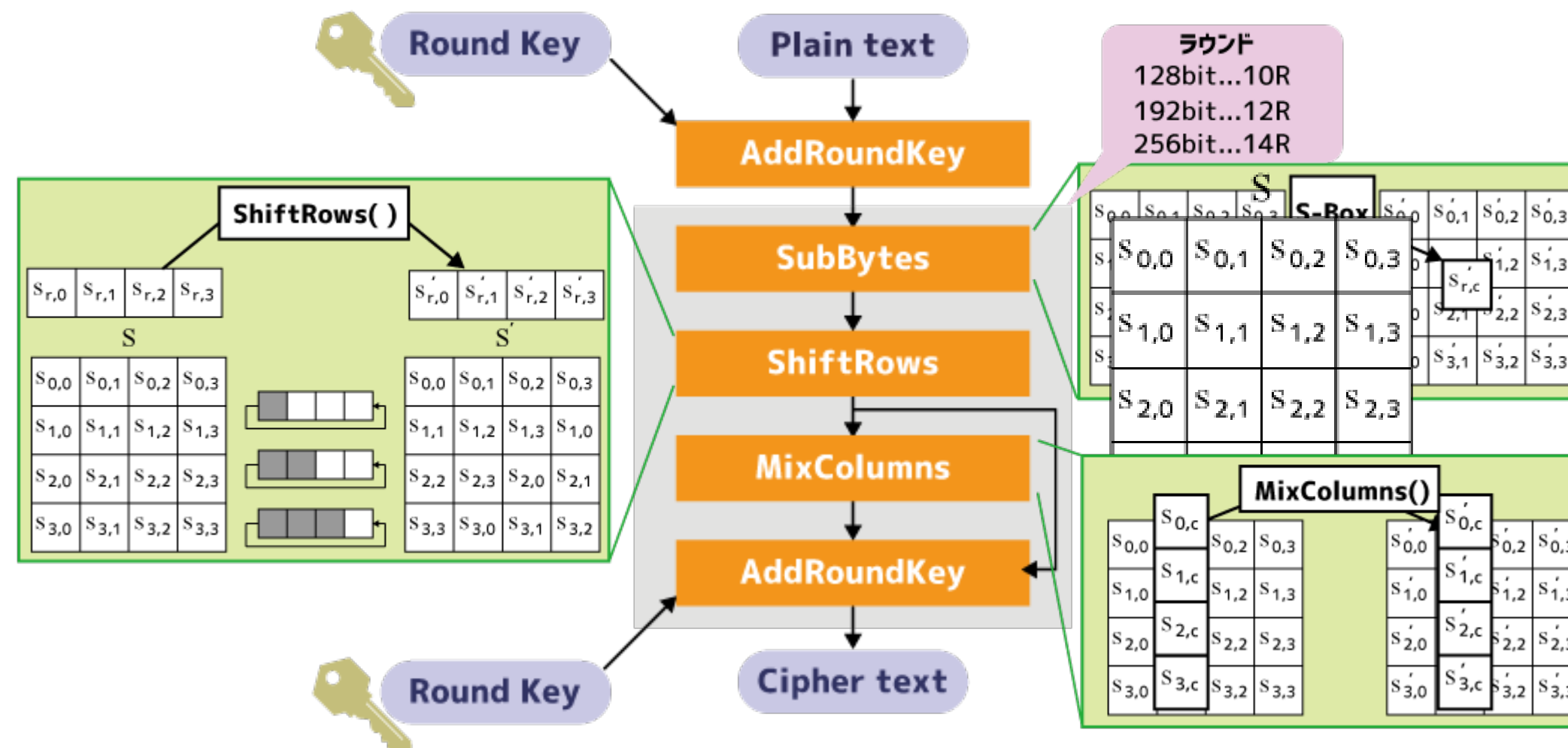
- 暗号化のときに使う鍵と復号の時に使う鍵が同じで共通鍵(Common Key)と呼ばれる
- 対象鍵暗号(Symmetric Cryptography)とも呼ばれる
- 元の文(message)を平文(plain text)、暗号化された文を暗号文(cipher text)と呼ぶ
- 暗号文は意味のない文字列になる
- 共通鍵暗号の代表的なアルゴリズム: AES、DES、Camellia
- 暗号化・復号が高速



k が取りうることができる範囲を鍵空間 (*key space*) と呼ぶ
128bit 鍵であれば 2 の 128 乗のケースがある

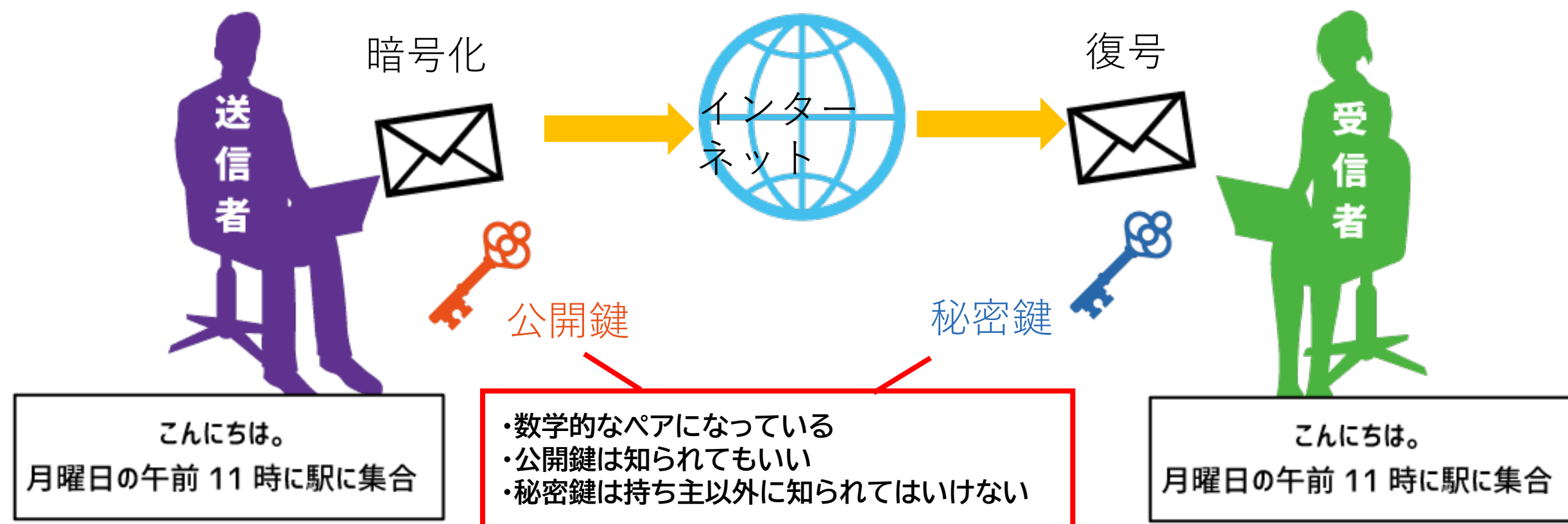
■AES(Advanced Encryption Standard)

- 共通鍵暗号のスタンダード、2001年米国で標準となる(FIPS197)
- データ長は**128bit**、鍵長**128, 192, 256bit**の3種類
- ハードウェア、ソフトウェアの実装が容易
- 換字(Substitution)と転置(Permutation)を繰り返すSPN構造



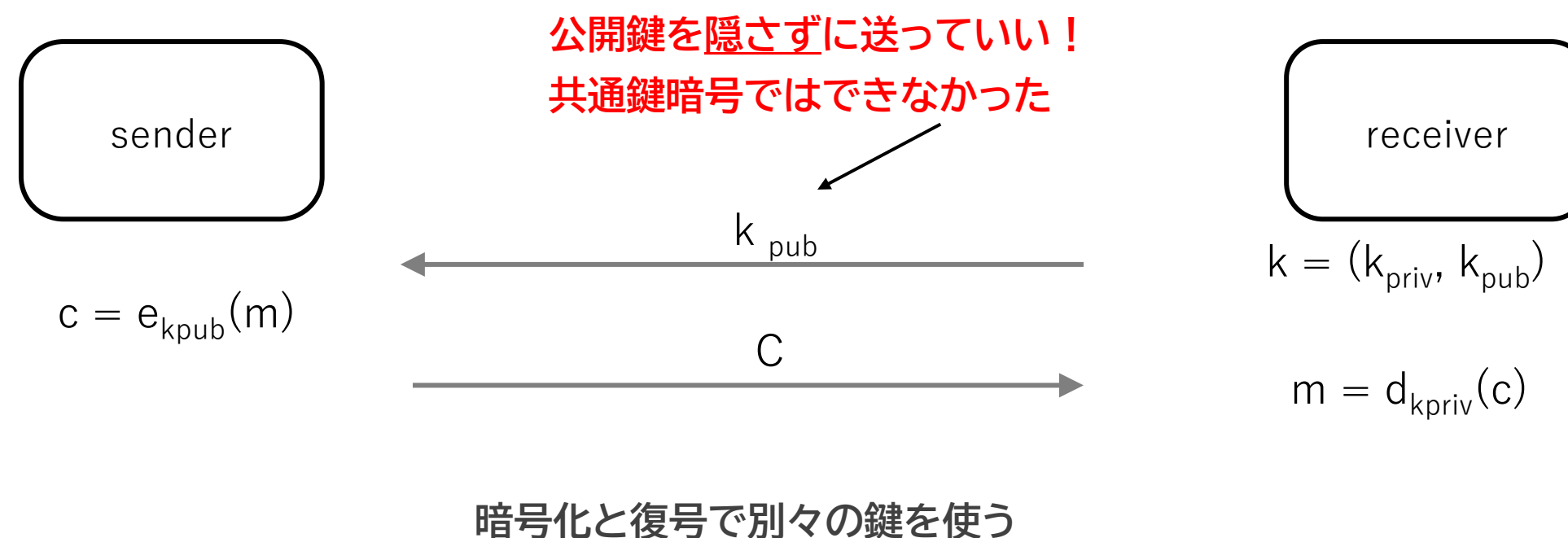
■公開鍵暗号(Public-key Cryptography)

- 暗号化のときに使う鍵と復号のときに使う鍵が異なる
- 公開鍵と秘密鍵は(数学的に)「対(ペア)」をなす
- 公開鍵は知られてもよい、秘密鍵を秘密にする
- 公開鍵で暗号化し、秘密鍵で復号する
- 非対称鍵暗号(Asymmetric Cryptography)とも言われる
- 代表的なアルゴリズム: RSA、楕円曲線暗号(ECC)



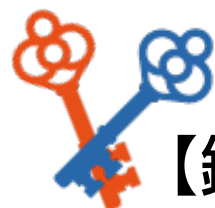
■公開鍵暗号(Public-key Cryptography)

- 暗号化のときに使う鍵と復号のときに使う鍵が異なる
- 公開鍵と秘密鍵は(数学的に)「対(ペア)」をなす
- 公開鍵は知られてもよい、秘密鍵を秘密にする
- 公開鍵で暗号化し、秘密鍵で復号する
- 非対称鍵暗号(Asymmetric Cryptography)とも言われる
- 代表的なアルゴリズム: RSA、楕円曲線暗号(ECC)



■RSA暗号

- Rivest、Shamir、Adelmanの3人が1977年に考案した公開鍵暗号のスタンダード
- 2,048～4,096bitのべき乗剰余演算
- 秘密鍵と公開鍵はべき指数のペア
- 公開鍵で変換すると秘密鍵でしか元に戻せない(暗号化)
- 秘密鍵で変換すると公開鍵でも元に戻せる(電子署名)



【鍵生成のアルゴリズム】

- 暗号鍵(e,N)を公開にし、復号鍵dを秘密にする
- 2つの大きな素数P,Qを任意に取り、**この2つは秘密にしておく**
- $N=PQ$ かつNが**2048bit**以上であること(P,Qはその半分)
- $\phi(N)=(P-1)(Q-1)$ 且つ $ed=1 \bmod \phi(N)$ を満たすe,dを探す

掛け算は簡単だが素因数分解(割り算)は難しいということを利用した暗号



■HTTPS(TLS)のRSA

- Firefoxを使うとサーバーの公開鍵(モジュラス(N)、指数(e))が確認できる

Firefoxのアドレスバーに「https://www.sunnygiken.co.jp」が表示されています。アドレスバーの左側には「安全な接続」のアイコンが赤い円で囲まれています。

アドレスバーの右側には「www.sunnygiken.co.jp のサイト情報」が表示されています。この情報には「安全な接続」のアイコンと「Cookie とサイトデータを消去...」のリンクがあります。

「安全な接続」のアイコンをクリックすると、「www.sunnygiken.co.jp への接続の安全性」のポップアップが表示されます。このポップアップには「このサイトとの接続は安全です。」と「認証局: Let's Encrypt」が表示されています。また、「詳細を表示」のボタンが赤い円で囲まれています。

「詳細を表示」をクリックすると、「証明書を表示(V)...」のボタンが赤い円で囲まれます。このボタンをクリックすると、証明書の詳細が表示されます。

証明書の詳細には「技術情報」のセクションがあり、接続が暗号化されていると示されています。また、「公開鍵情報」のセクションがあり、アルゴリズムがRSA、鍵サイズが2048、冪剰余が65537と表示されています。母数（モジュラス(N)）の値が16進数で512桁表示されています。

モジュラス (N) が 2048 bit (16進数で 512桁) あるか確認

■共通鍵暗号と公開鍵暗号

■共通鍵暗号

- ✓申し合わせた秘密の鍵を使用する
- ✓メリット : **高速・低コスト** 実装コスト(ハード・ソフト)が比較的低い
- ✓デメリット: **鍵共有・鍵管理**の手間

鍵共有問題 : 鍵を如何にして共有するか

鍵管理問題 : 多くの鍵を管理しておく必要がある



■公開鍵暗号

- ✓暗号鍵は公開し、復号鍵を秘密にする
- ✓メリット : **鍵共有不要・認証機能** 鍵を公開できるための鍵共有が不要
自分の秘密鍵だけを管理しておけばよい
認証機能実現できる
- ✓デメリット: **低速・高コスト** 巨大な桁の計算が必要なため実装コストが高い



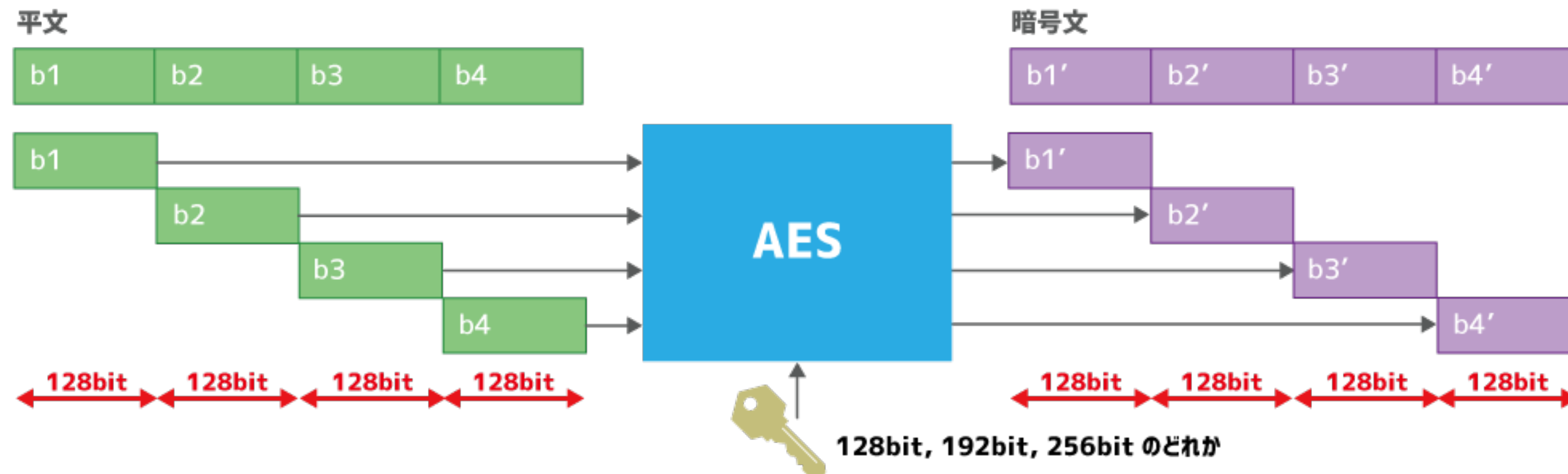
■ハイブリッド暗号

- ✓公開鍵で鍵を配送し、共通鍵暗号で通信
- ✓両者のメリットを活かす実用的解決策、ただし実装コストは高い



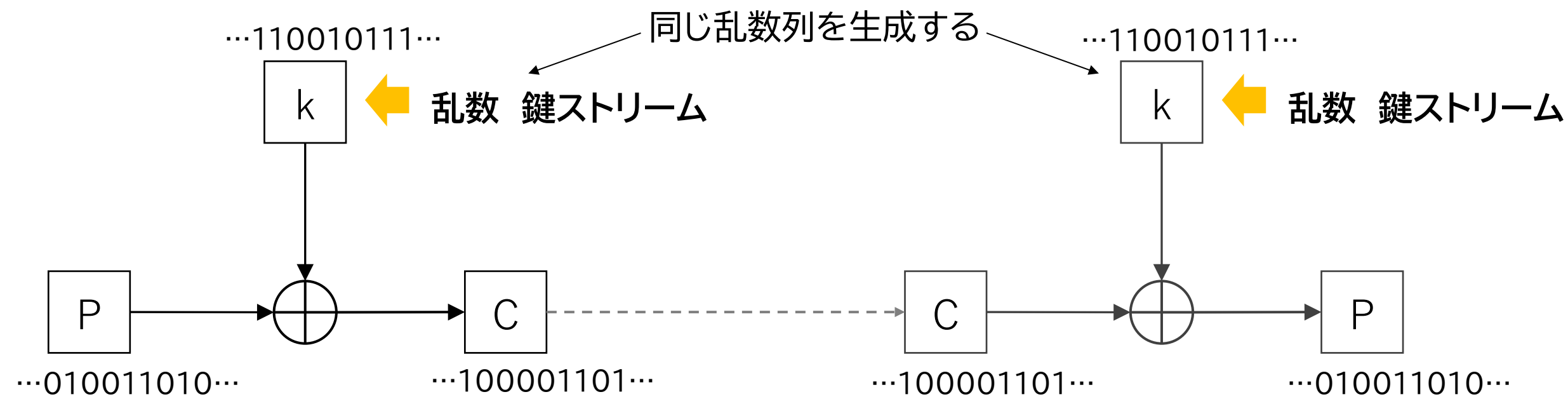
■ ブロック暗号(Block cipher)

- 平文を特定の長さ(ブロック)に分けて暗号化する方法
- メッセージをブロックに分割し、暗号化
- AES: ブロック暗号のデファクト・スタンダード
 - データ長 128bit
 - 鍵長 128bit, 192bit, 256bitの3種類
- ブロック長に足りないときは詰め物(パディング、padding)をする



■ ストリーム暗号(Stream cipher)

- 暗号化:1ビット単位で、鍵(乱数)をXOR
- 復号:同じ値を再度XOR
 - 暗号化と復号が同一処理でよい(処理がシンプルになる)
- ブロック暗号をCTRモードで利用することでストリーム暗号を実現可能
- 代表的なアルゴリズム:Kcipher-2, MUGI, RC4, ChaCha20(TLS)



暗号化 1ビット XOR } どうしてこれで安全(セキュア)なのか?
復号 1ビット XOR }

■いまさらのXOR

- $X + Y + Y = X$

同じ値をXORすると消える

— 足し算でもあり、引き算でもある

— ハードウェアとも相性が良く、暗号で多用される (AESのAdd Round KeyはXOR)

- X を平文、 Y を鍵、 $X + Y$ を暗号文と見立てる

「送信者と受信者は秘密鍵 Y を共有し、アタッカーは $X + Y$ を盗聴する」

X	Y	X+Y
0	0	0
0	1	1
1	0	1
1	1	0

暗号文 $X + Y$ が 0 のとき:

「 X が 0 で Y が 0」の確率 50%

「 X が 1 で Y が 1」の確率 50%

暗号文 $X + Y$ が 1 のとき:

「 X が 0 で Y が 1」の確率 50%

「 X が 1 で Y が 0」の確率 50%

攻撃者は平文についてなにもわからないのと同じ
(ただし Y は予測不可能であること)

■暗号技術入門 まとめ

■扱う鍵による分類

・共通鍵暗号(Common key cryptography)

—コストが安い、高速

・公開鍵暗号(Public-key cryptography)

—コストが高い、低速、鍵を公開できる

■処理の仕方による分類

・ブロック暗号(Block cipher)

—決まったブロック長単位で処理

—暗号化と復号の処理がある

・ストリーム暗号(Stream cipher)

—ビット単位でXOR

—暗号化と復号が同じ

—ブロック暗号を応用しても実装できる

■現代暗号は鍵だけが秘密であり、手続きは隠さない

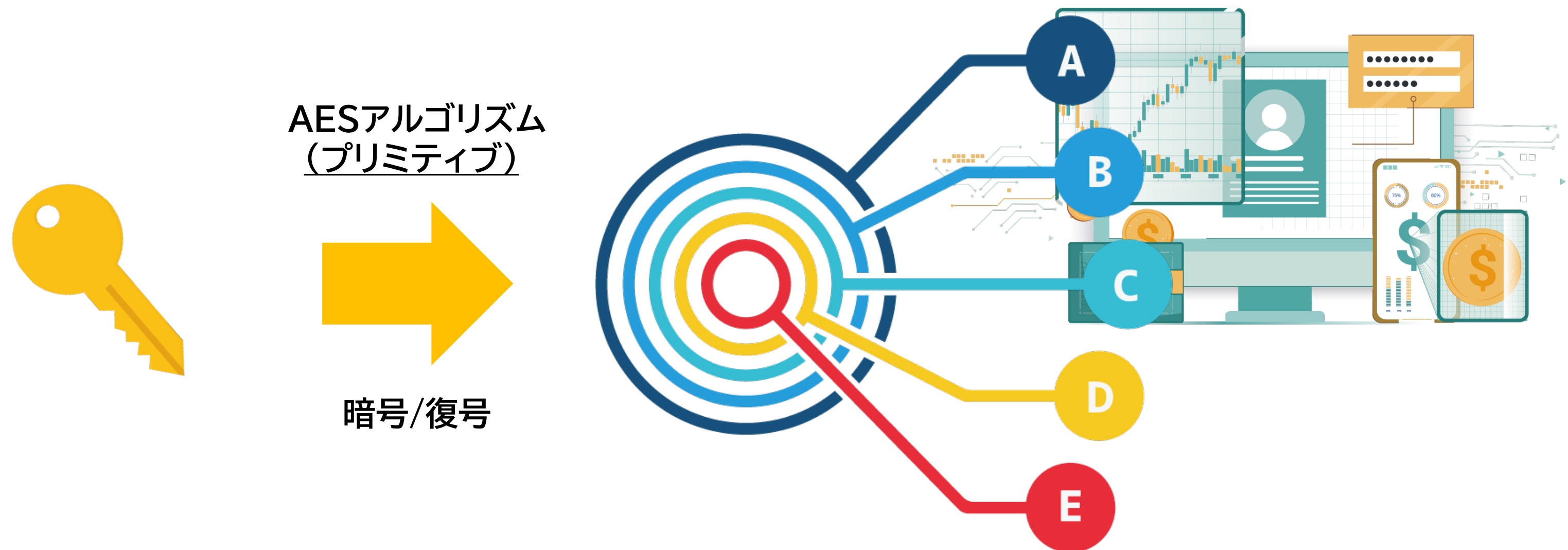
■第5章 ブロック暗号の利用モード

【習得内容】

- ・ブロック暗号の利用モードとは
- ・暗号に対する代表的な攻撃/解析

■ブロック暗号の利用モードとは

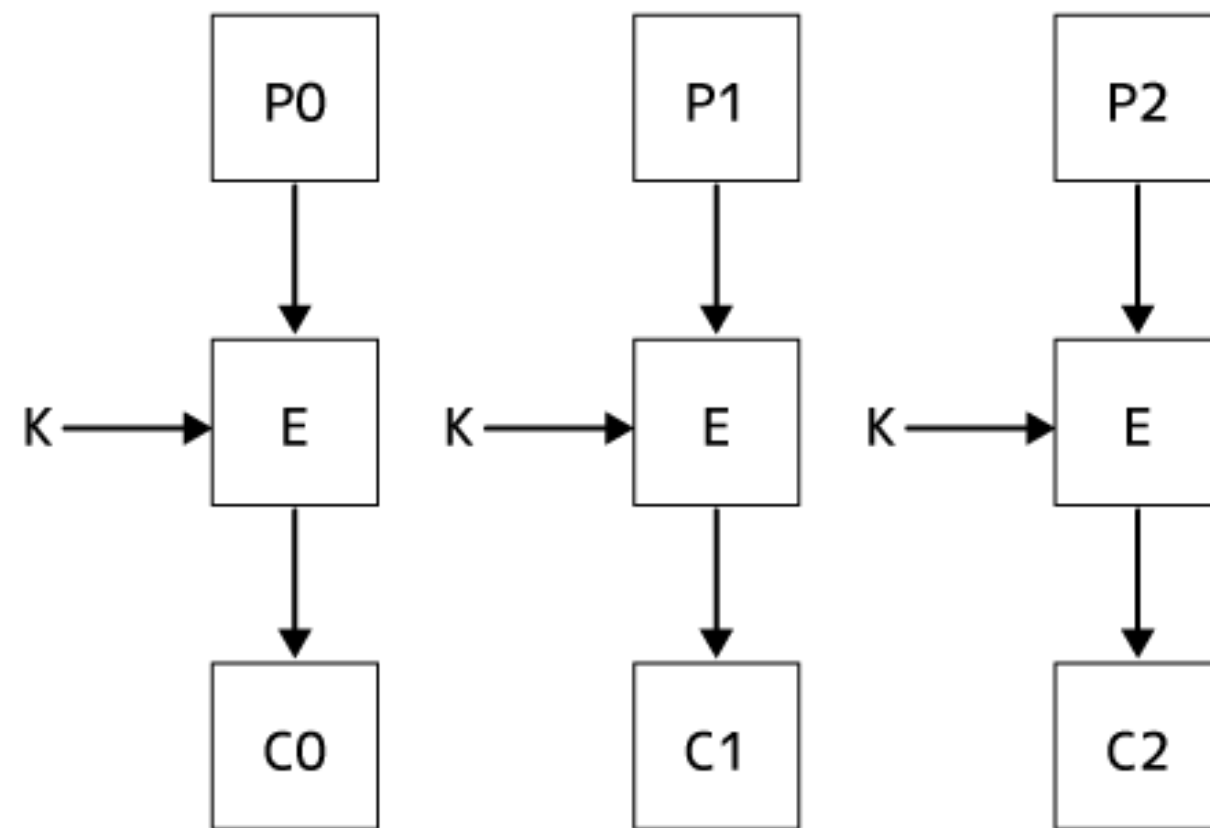
- AES、DESなどベースとなる暗号アルゴリズムをプリミティブ(primitive)と呼ぶことがある
- **利用モードとは、複数ブロックを暗号化するときのプリミティブの使い方**



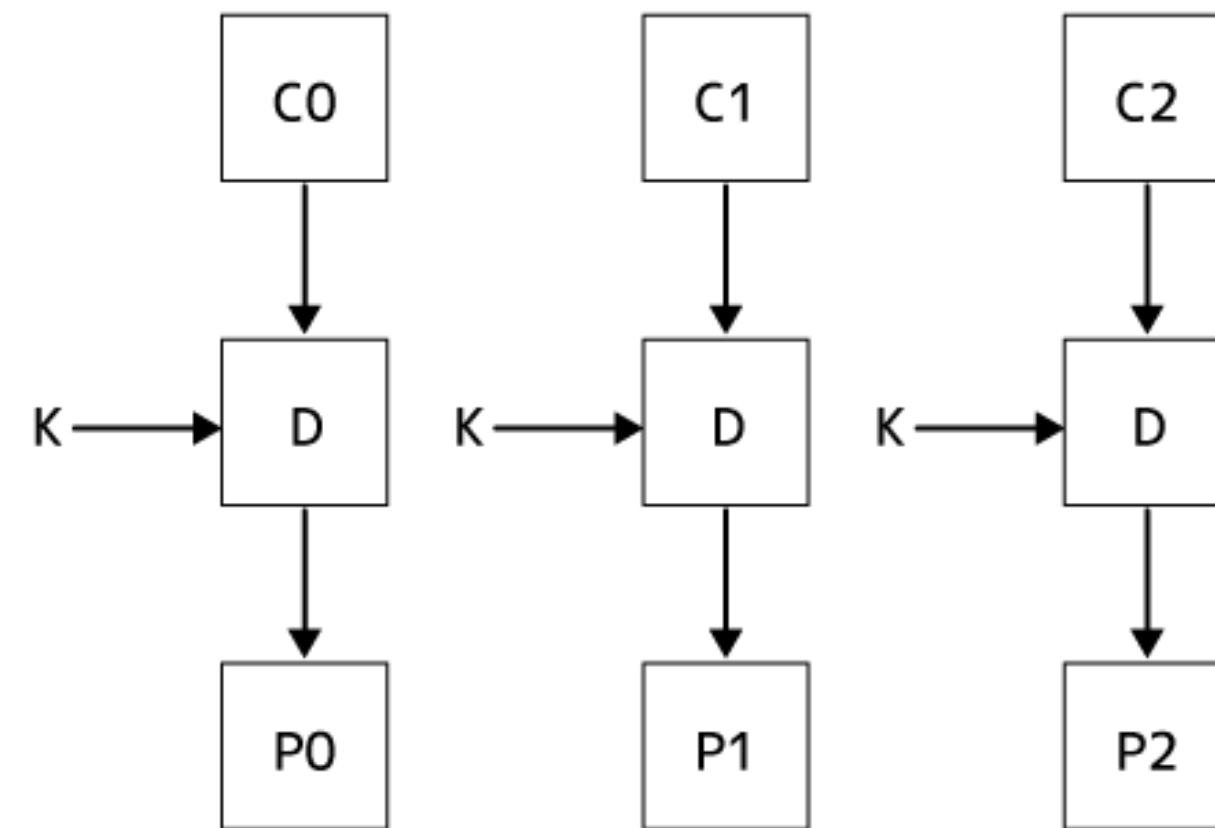
暗号を使うのは難しくありませんが、使い方には注意が必要です(モード)

■ECB(Electric Code Book)モード

- そのままブロック単位で暗号化する
- 利点: シンプル・わかりやすい
- 欠点: 同じ平文からは同じ暗号文が出る ➡ 平文の傾向が暗号文に残る



暗号化ステップ



復号ステップ

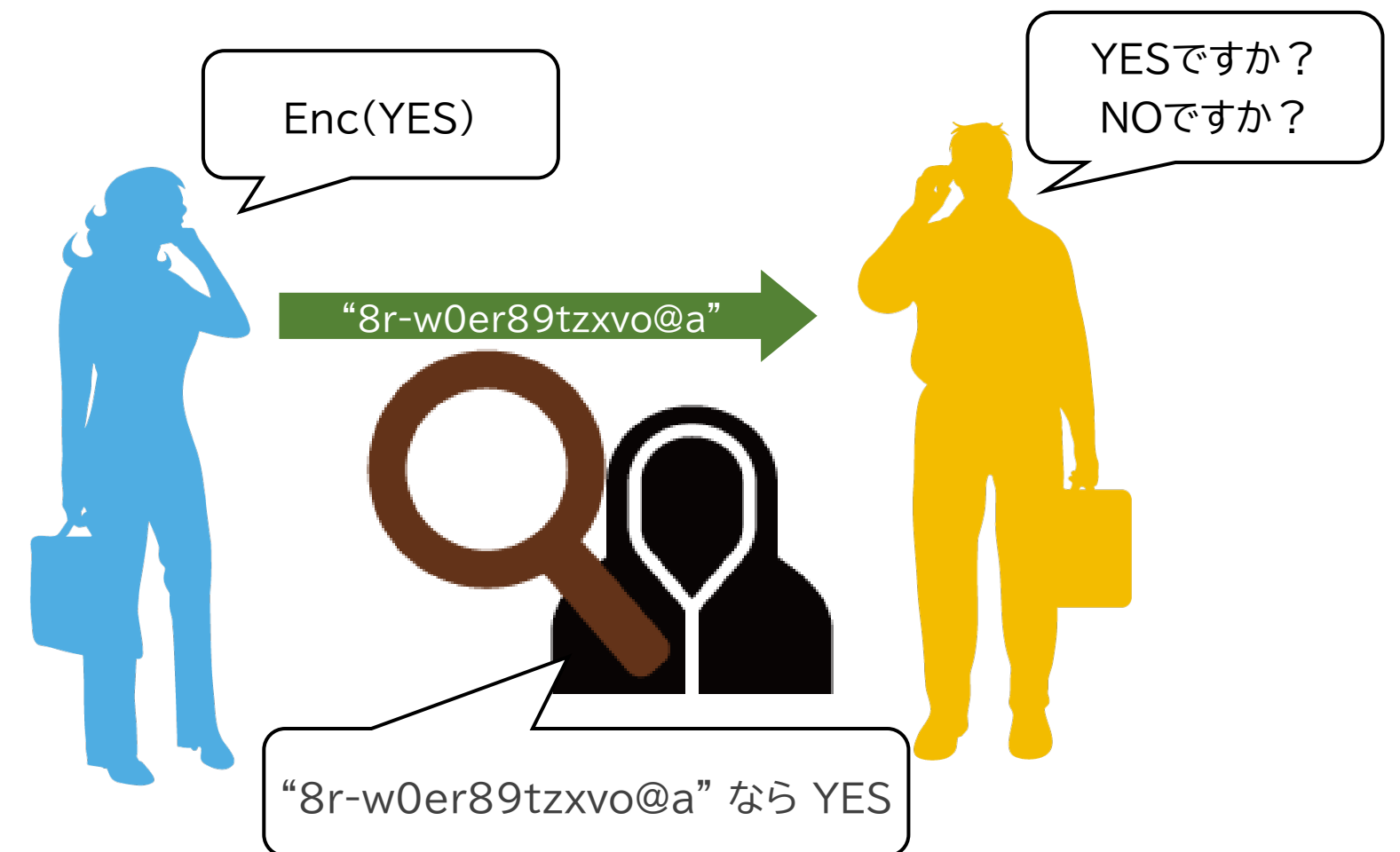
P0 : 平文
K : 鍵
E : 暗号化
D : 復号
C0 : 暗号結果

■ECB(Electronic Code Book)モード

- ・そのままブロック単位で暗号化する
- ・利点: シンプル・わかりやすい
- ・欠点: 同じ平文からは同じ暗号文が出る → 平文の傾向が暗号文に残る



画像のECBモード暗号化
画像(平文)の特徴が残っている



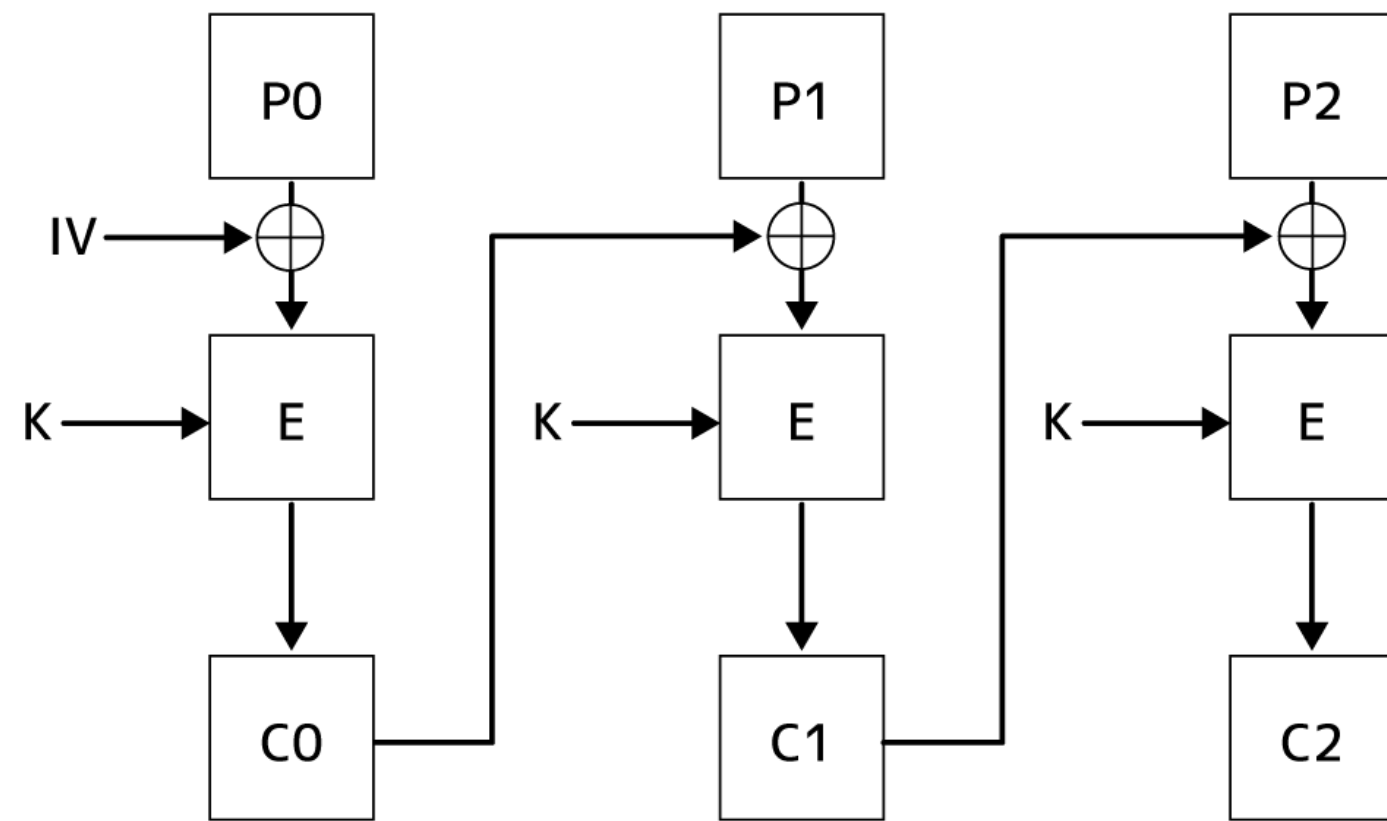
保存しておいてあとで再利用する

再送攻撃

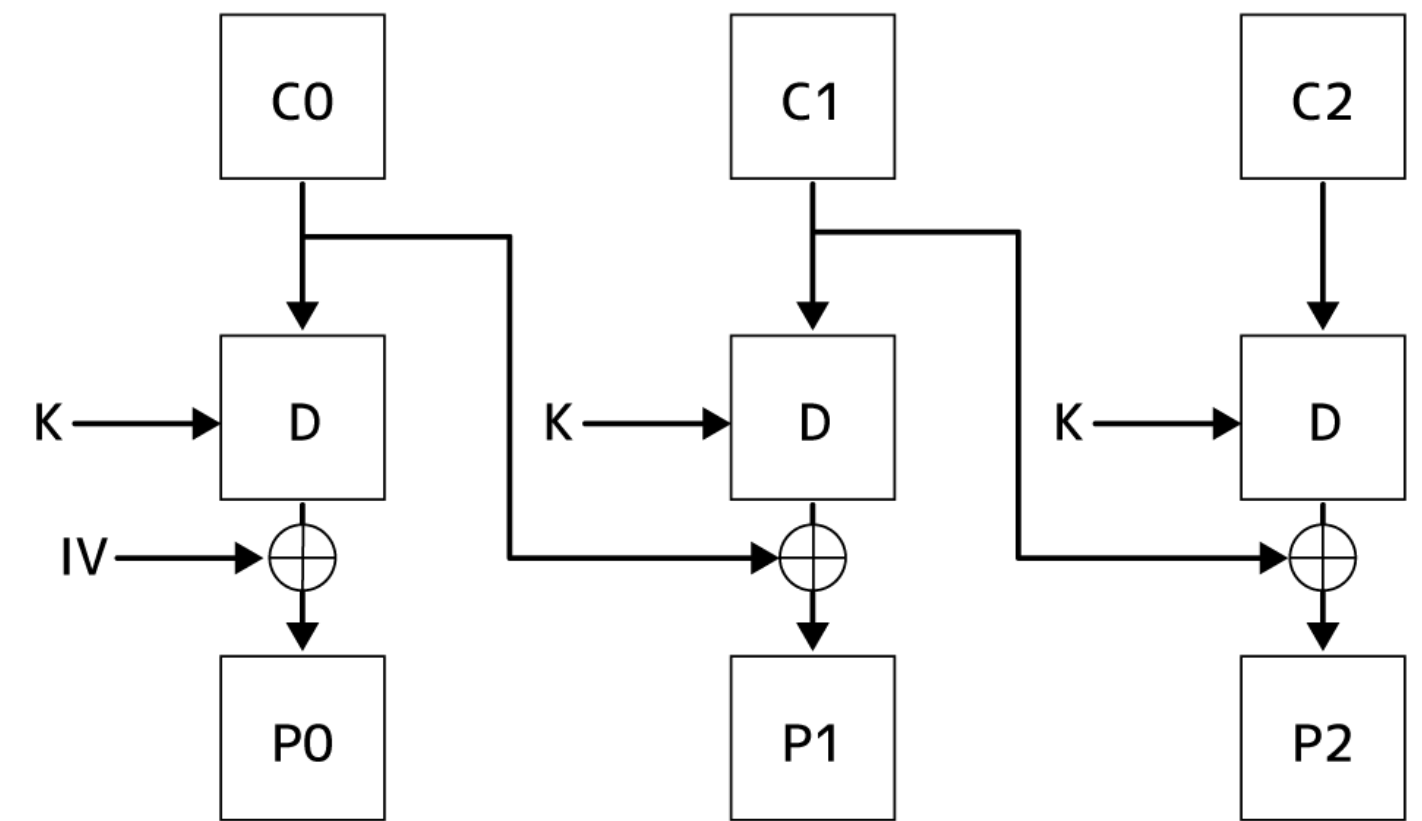
結論: ECBは脆弱なため、使わないこと

■CBC(Cipher Block Chaining)モード

- 1ブロック目の暗号化が2ブロック目に、2ブロック目の暗号が3ブロック目に……ドミノ倒し
- 初期値(イニシャルベクタ、*initial vector* (IV))が必要
- IVは公開してよい
- IVによって同じ平文でも暗号結果が変化→ECBの欠点を解消
- 並列化できない(手前の暗号化ができてないと処理が進めない)



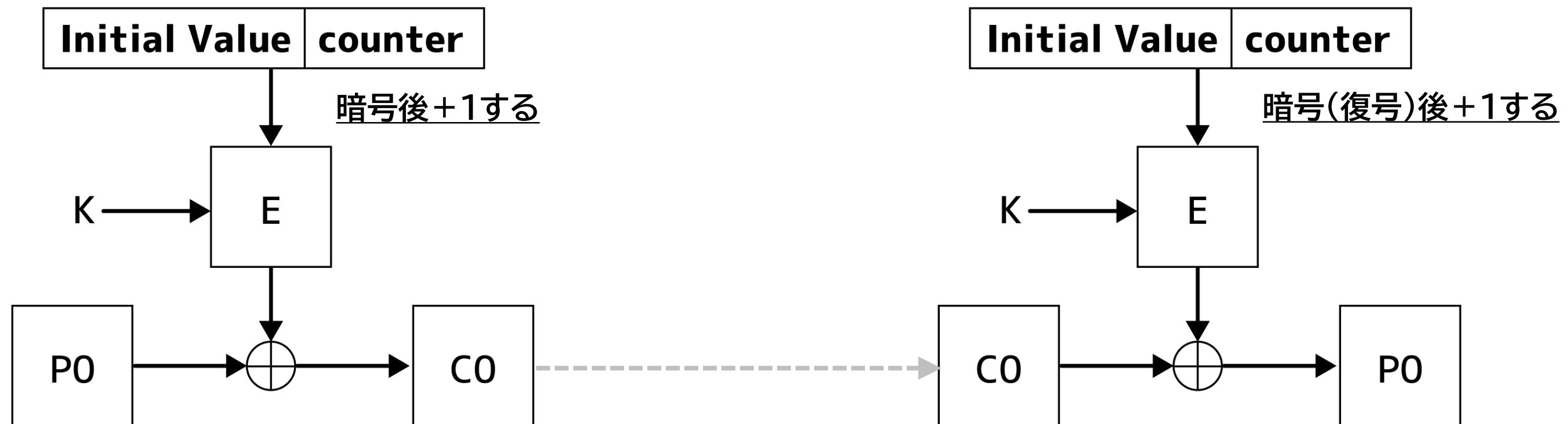
暗号化ステップ



復号ステップ

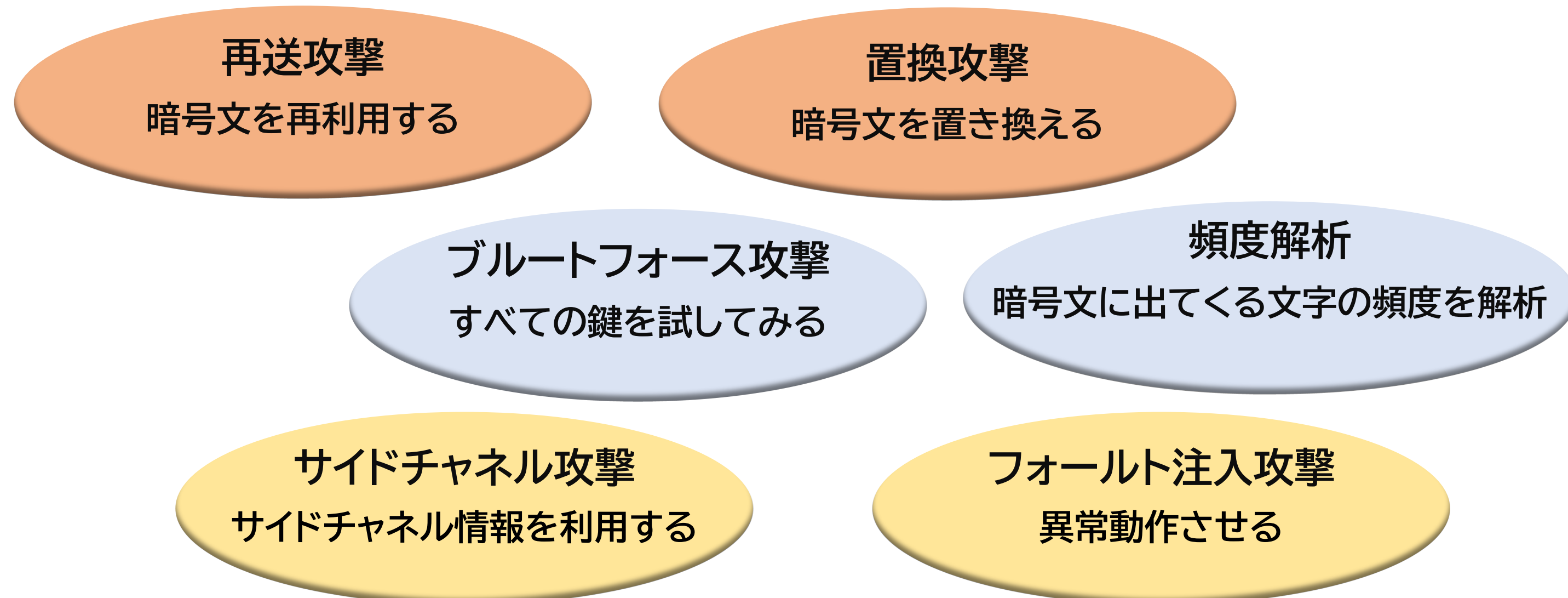
■CTR(Counter)モード

- 暗号を疑似乱数生成器として利用
- カウンターを暗号化する
- 並列処理
- ブロック長にしばられない(ビット単位で暗号化できる)→ **ストリーム暗号に**
- 暗号機能だけでいい(復号機能は不要)
- カウンターの初期値を再利用してはいけない(毎回同じ値とのXORになってしまう)
ナンス(Nonce)であること(「二度と同じ値がでない」特性の値)



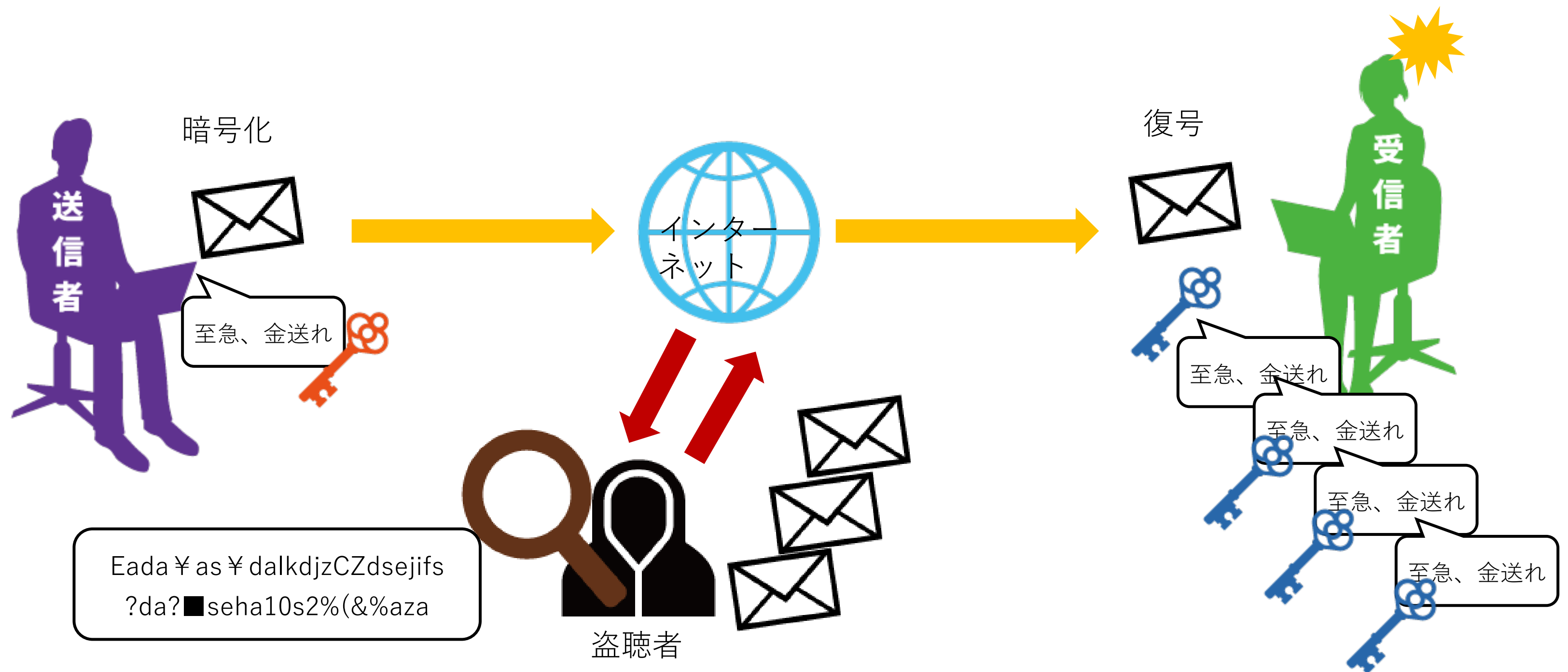
■暗号に対する代表的な攻撃/解析(Attack/Analysis)

- ・さまざまな攻撃方法があり、攻撃の難易度、コストも異なる
- ・必ずしも鍵を解読するだけではない(再送攻撃・置換攻撃)
- ・アルゴリズムを対象とした攻撃、できあがった製品を対象とした攻撃(サイドチャネル攻撃・フォールト注入攻撃)という区分も存在



■再送攻撃(Replay Attack)

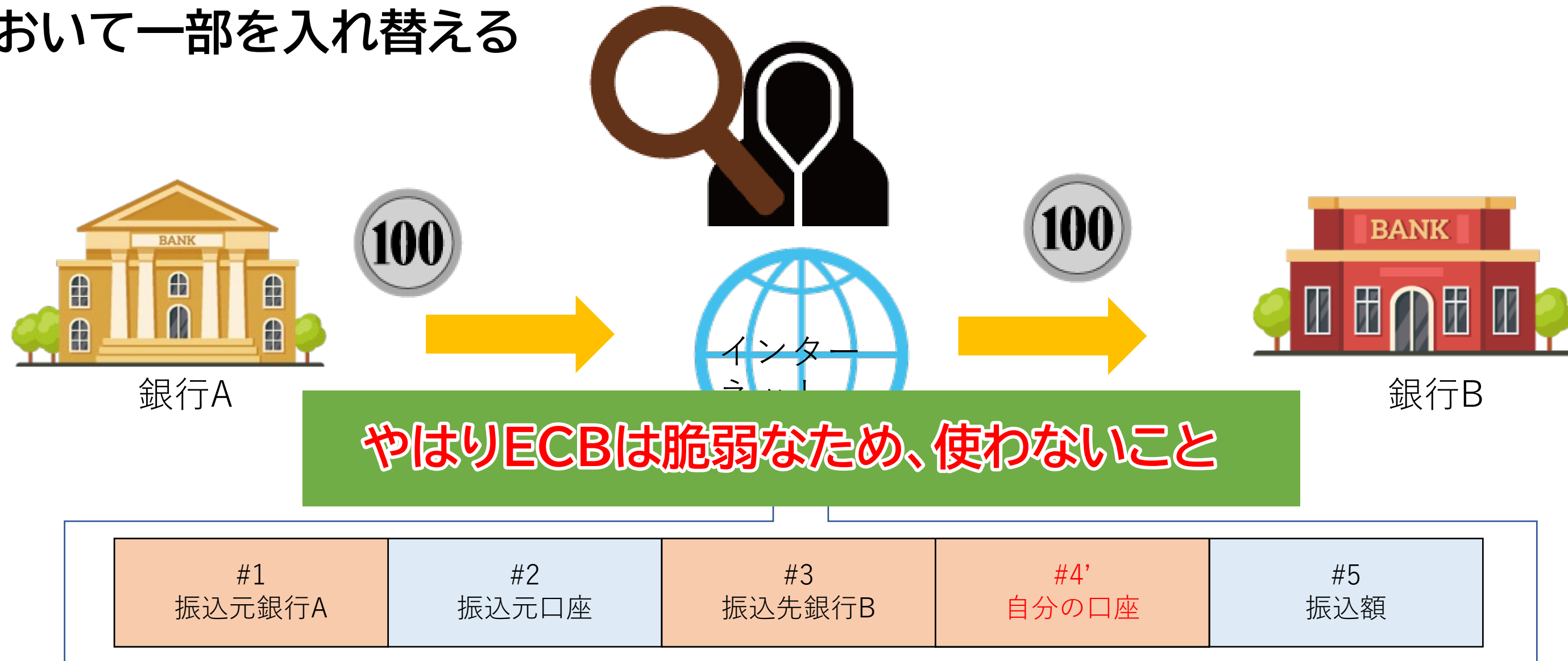
- ・ネットワークに流れるデータを保存して、後日再利用する



ショッピングサイトへ偽の注文が出来る

■置換攻撃(Substitution)

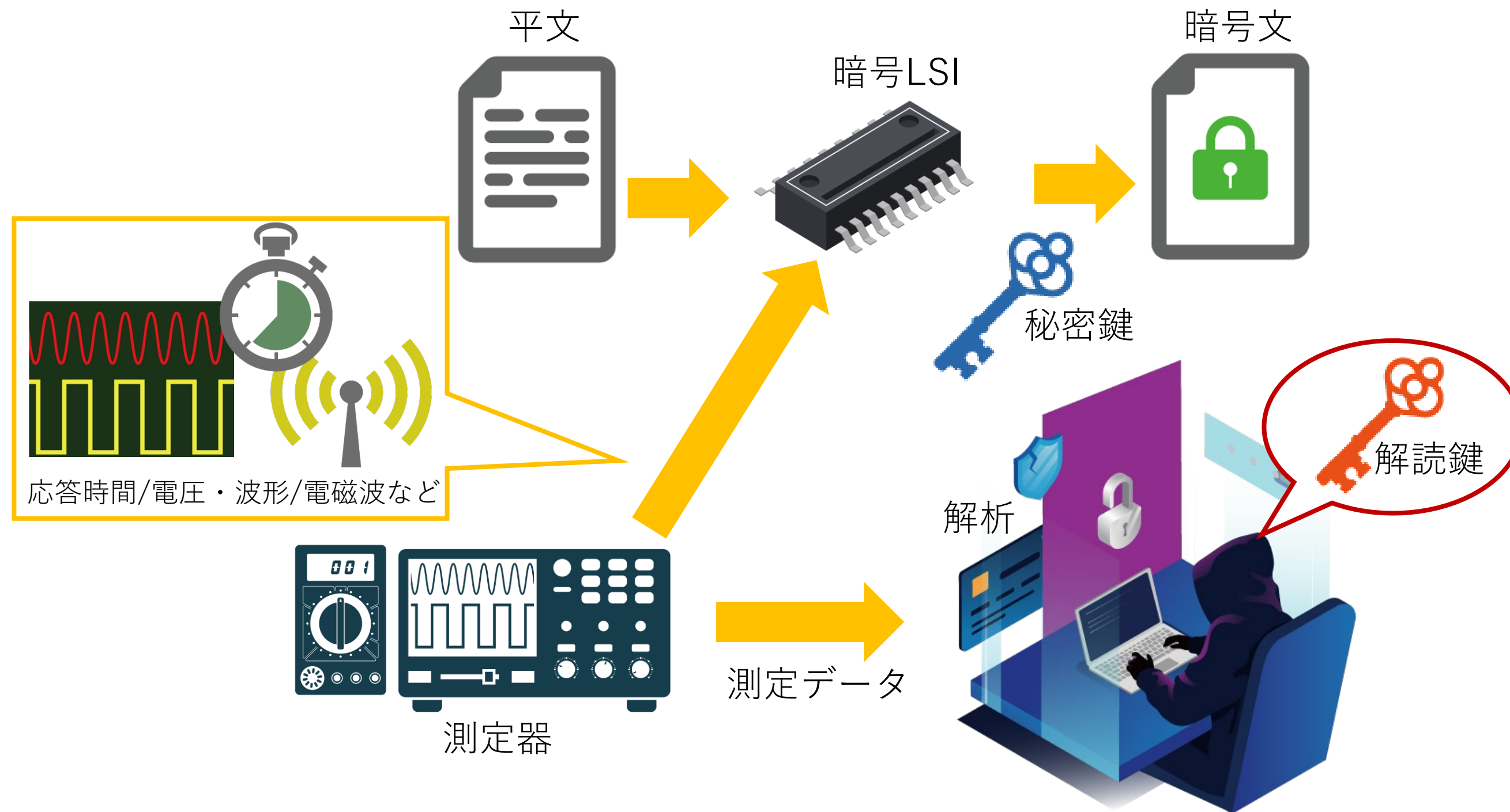
- ・保存しておいて一部を入れ替える



- 1) アタッカーは銀行A、Bに口座を作る
- 2) 何回か100円を振り込み、上記のようなメッセージが**同じ鍵**で暗号化されているのがわかったので
#1, #3, #4を保存しておく
- 3) 後日アタッカーは、#1, #3に合うメッセージを見つけたら、#4を保存しておいたものと置き換える

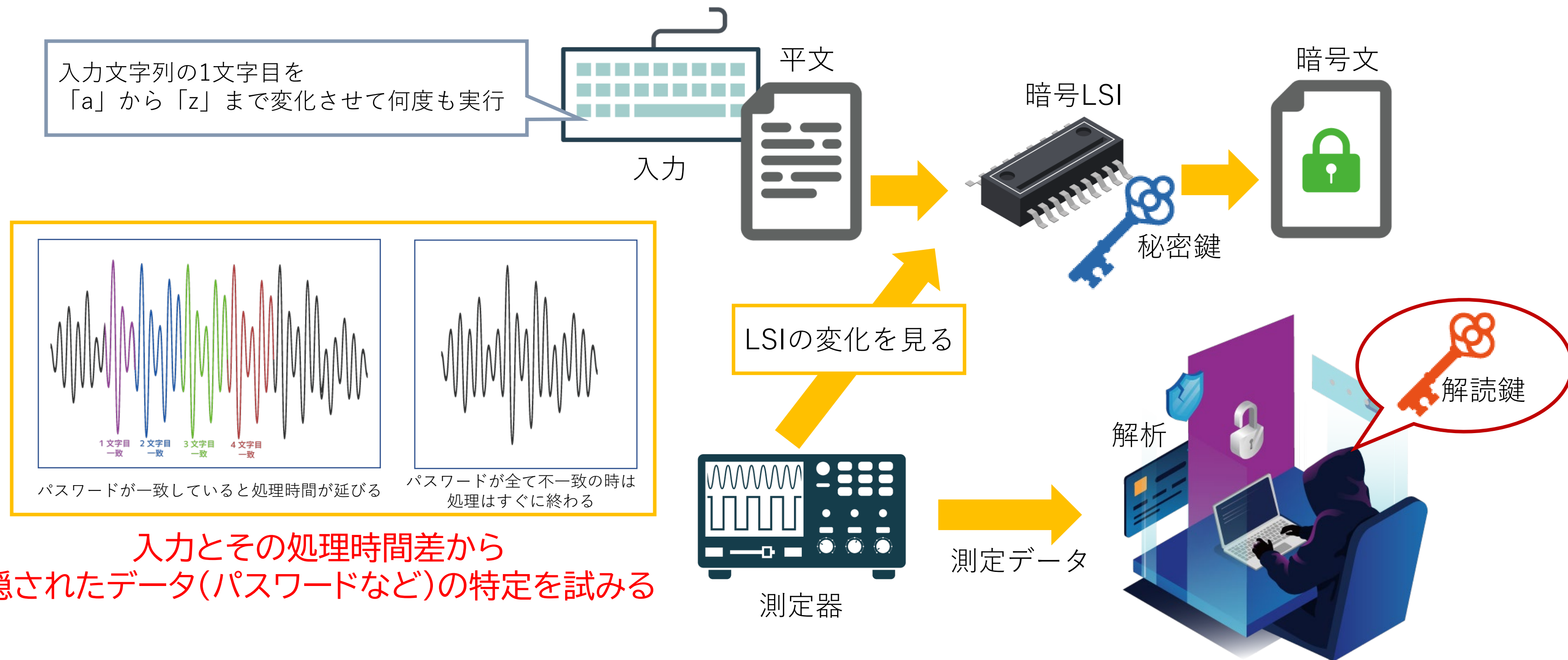
■サイドチャネル攻撃

- ・動いている装置から出る電流や電磁波・振動など物理的特性を計測して暗号解析の手がかりを得る攻撃



■サイドチャネル攻撃(タイミングアタック)

- ・暗号装置に複数の入力を与えて、その処理時間の差を読み取ることで鍵を見つけようとする



入力とその処理時間差から
隠されたデータ(パスワードなど)の特定を試みる

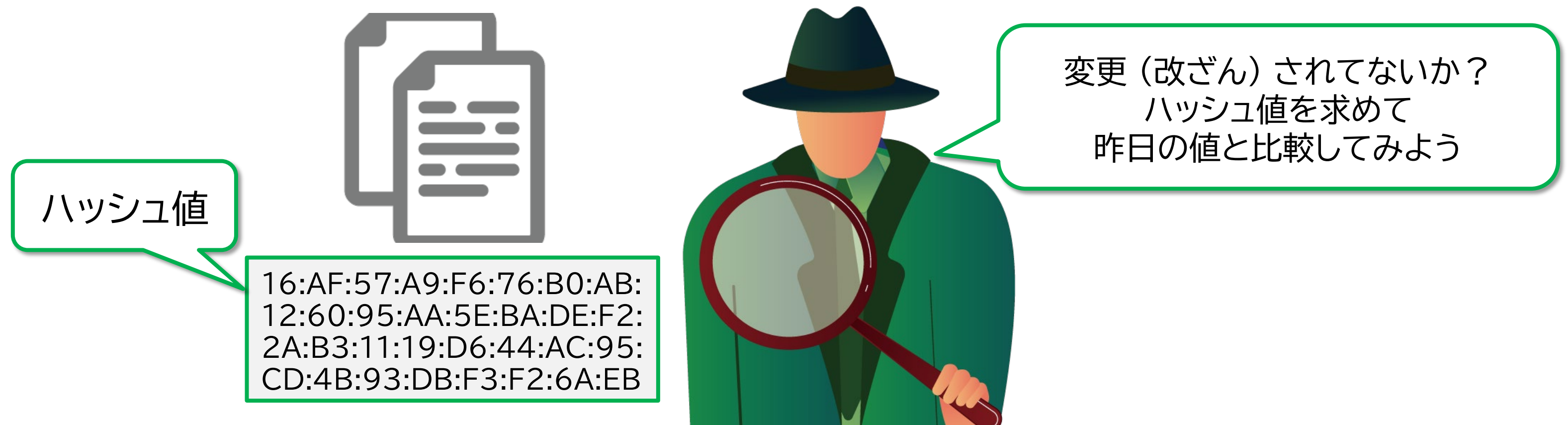
■第6章 ハッシュ関数とMAC情報の改ざんを防ぐ技術

【習得内容】

- ハッシュとは何か
- HMACとCMACの処理イメージ(メッセージ認証)
- AUTOSAR SecOC

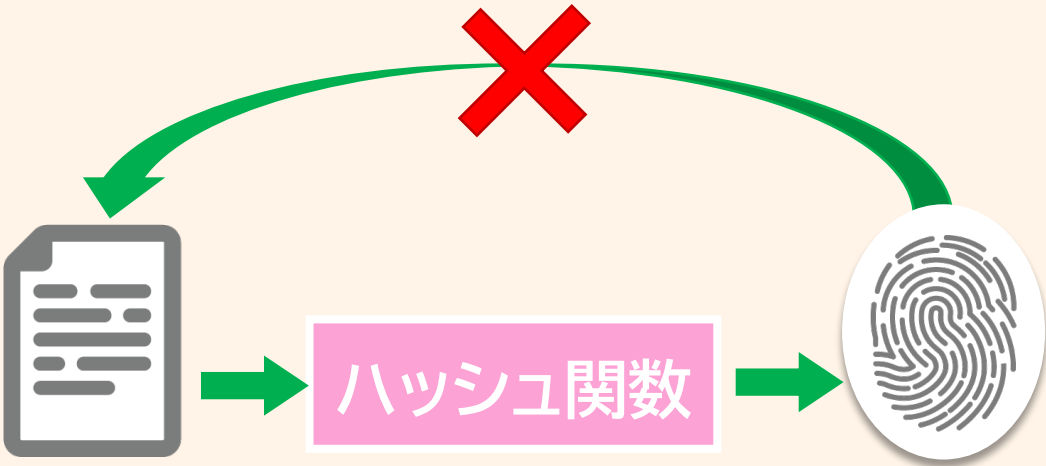
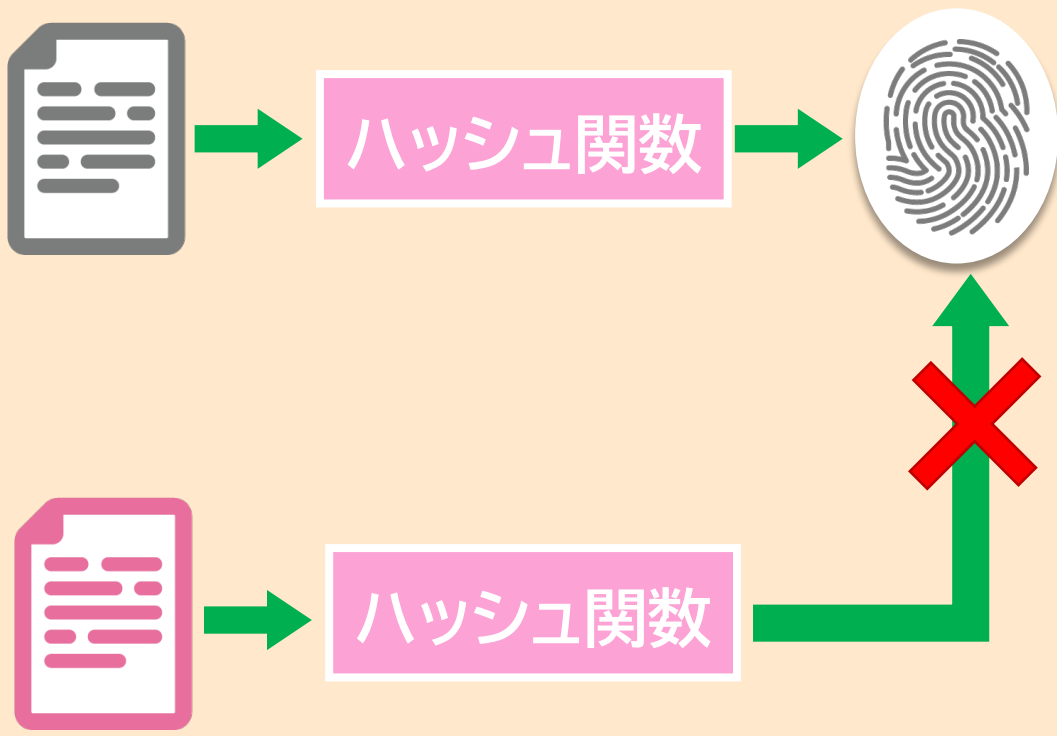
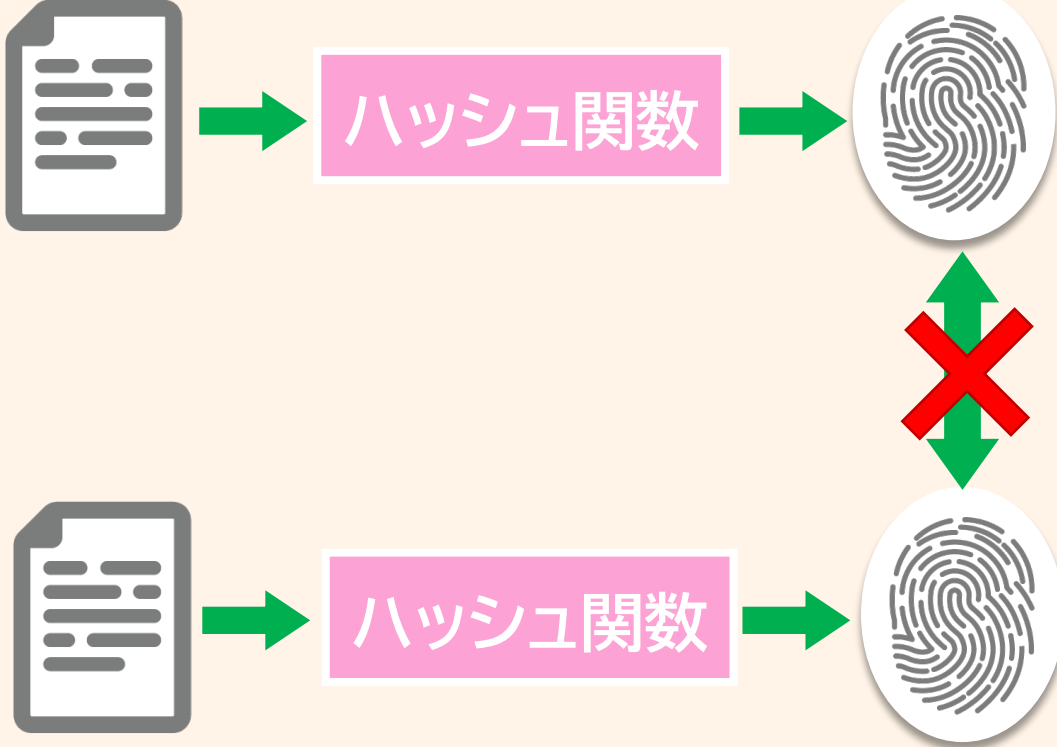
■ハッシュ関数

- 任意のデータから、ある一定の長さ(例えば256bit)のデータ(ハッシュ値)を作り出す
指紋(FingerPrint)、ダイジェスト(Digest)といった呼び方も
- ハッシュド・ビーフ、ハッシュド・ポテトのハッシュ(「切り刻む」)の意味がある
- 情報を秘匿を目的としない
- 代表的なアルゴリズム: **MD5**、**SHA1**(廃止)、SHA2、SHA3、BLAKE2



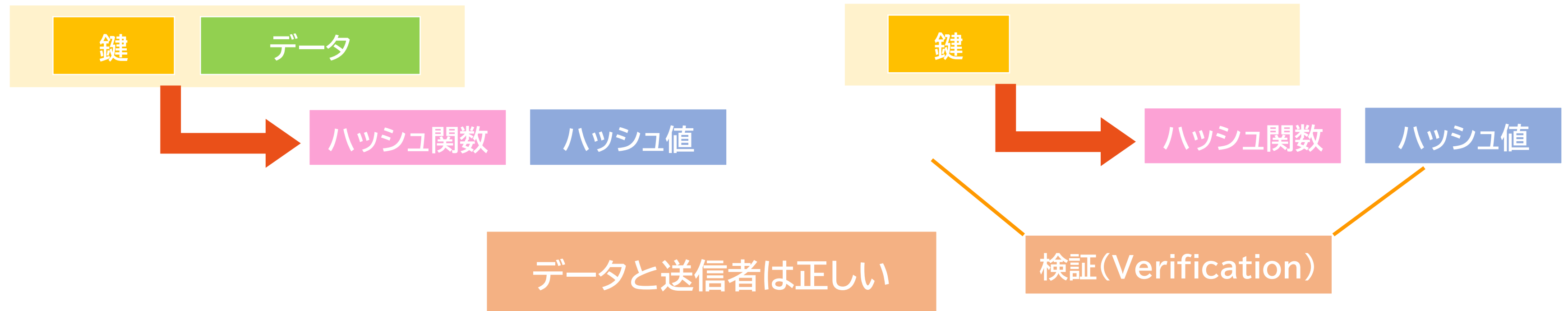
もし $H(P_{\text{yesterday}}) \neq H(P_{\text{today}})$ ならば改ざんされている！

■ハッシュ関数に求められる性質

原像計算困難性(一方向性)	第二原像計算困難性	衝突困難性
ハッシュ値 h から元の m を見つけることが難しいこと(逆をたどれないようにする) 	$m1$ があるとき、$H(m1)$ と同じハッシュ値となる $m2$ を求めるのが難しいこと 	相異なる $m1$ と $m2$ で同じハッシュ値とならないこと 

■Hash-based Message Authentication Code(HMAC)

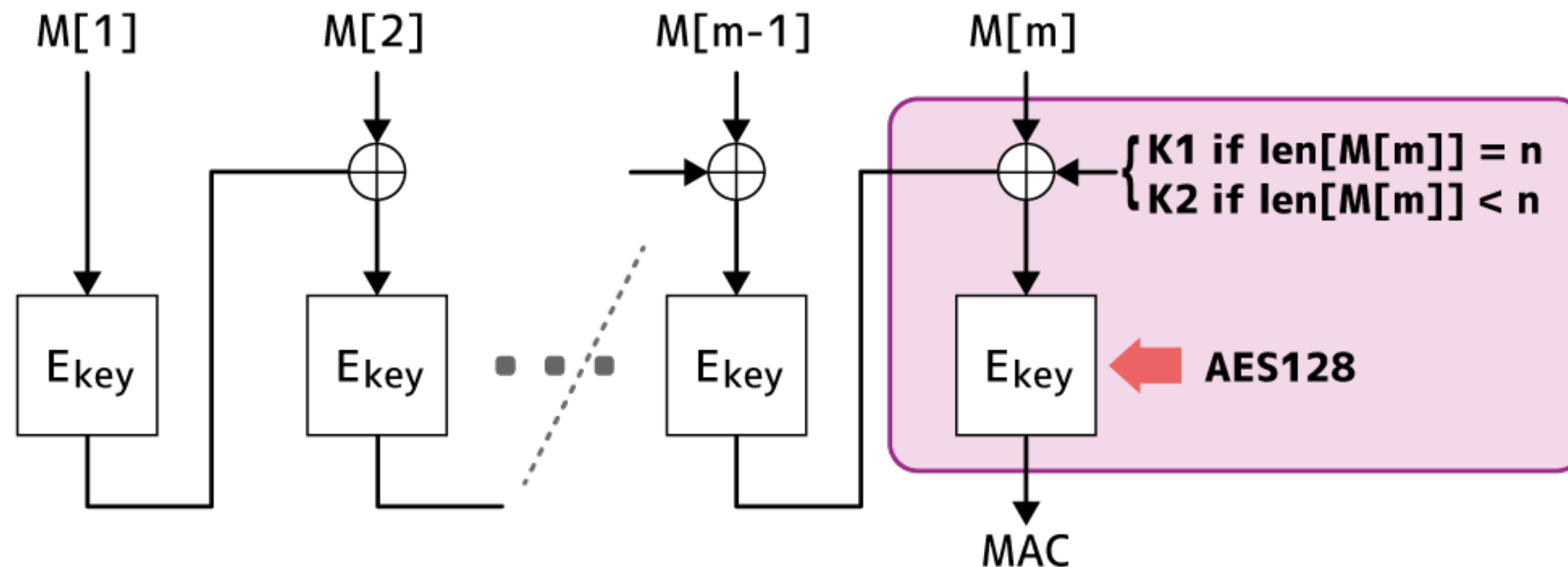
- ・ハッシュを認証に使う
- ・送信者と受信者で秘密情報(鍵)を共有する
- ・ハッシュ関数の入力にその秘密情報を含める
- ・データとハッシュ値を送る/受信者も同じ計算をする
- ・データは秘匿されないことに注意



1. 鍵が正しい、送信者が送ったものである **メッセージ認証(Message Authentication)**
2. メッセージは改ざんされていない **完全性(Integrity)**

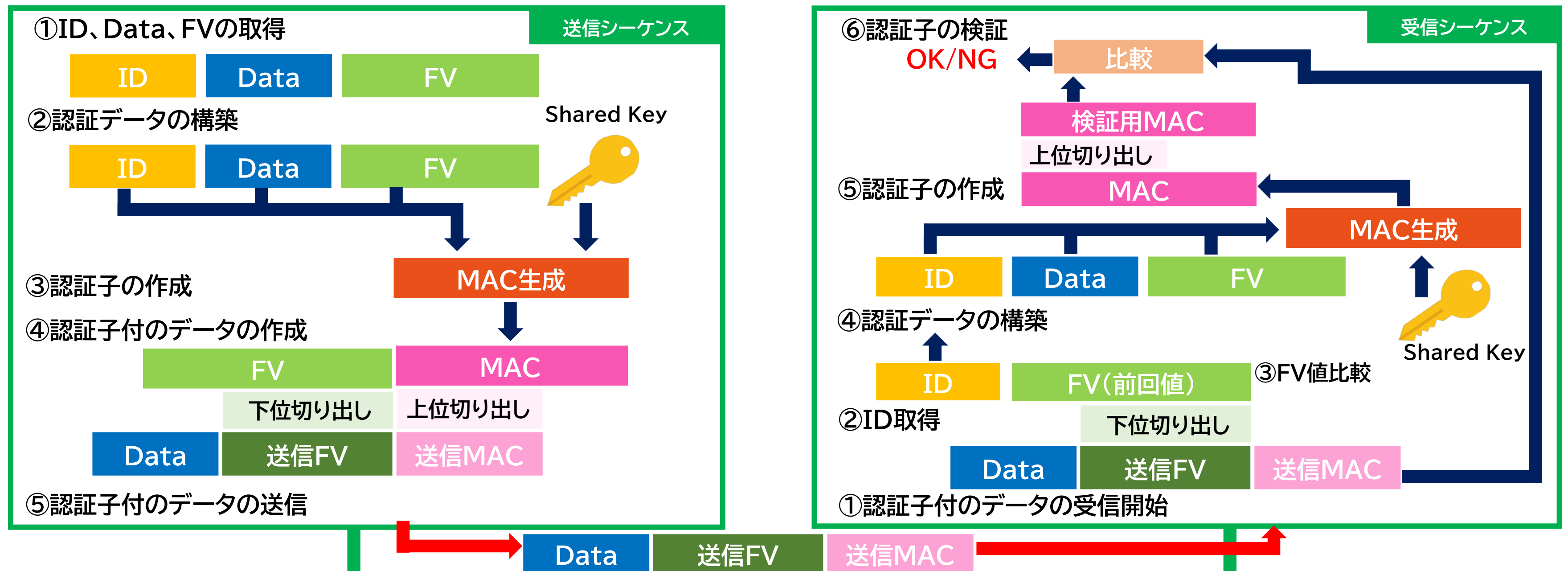
■AES-CMAC

- AESをメッセージ認証に使う (Cipher-based message authentication code)
- 標準: NIST recommendation (SP800-38B)、RFC4493
- CBCモードを利用したメッセージ認証コード、アルゴリズム
- ひとつのマスター鍵を共有
- マスター鍵からサブ鍵K1、K2を生成
- 最終ブロックを長さに応じてK1またはK2でマスクすることで「伸長攻撃」への対策とする



AUTOSAR Secure Onboard Communication

- AES-CMACアルゴリズム
- 再送攻撃(replay attack)を防ぐためのカウンタ(Freshness Value)
- 受信ECUは不正なMAC値を持ったメッセージを破棄する



■AUTOSAR Secure Onboard Communication

- MACのアルゴリズムや各種認証データのサイズは設定により変更可能
- AUTOSARでは以下の3種のSecOC Profileを定義
 - SecOC Profile1 (24Bit-CMAC-8bit-FV)
 - SecOC Profile2 (24Bit-CMAC-No-FV)
 - SecOC Profile3 (JASPAR仕様)

Parameters	Profile1 (24bit-CMAC-8bit-FV)	SecOC Profile2 (24bit-CMAC-No-FV)	SecOC Profile3 (JASPAR仕様)
アルゴリズム	CMAC/AES-128	CMAC/AES-128	CMAC/AES-128
FV長	Not Specified	0	64bit
TFV長	8bit	0	4bit
TMAC長	24bit	24bit	28bit

■第7章 Root of trust(信頼の基点)

【習得内容】

- ・Root of Trust(信頼の基点)の概要と期待される研究
- ・どの暗号を使うべきなのか

■鍵をどうするか-Key management-

- IoTあるいはM2M(Machine to Machine)はさまざまなデバイスが人を介さずに直接通信を行う
- センサーデバイスから集められた「Big Data」を利用したリアルタイムマネジメントによりさまざまなサービスが展開されようとしている
- 最終的に暗号は「**鍵をどう作り、どう配布し、どう管理する(守る)か**」という「**鍵管理**」に行き着く



■Root of trust(信頼の基点)

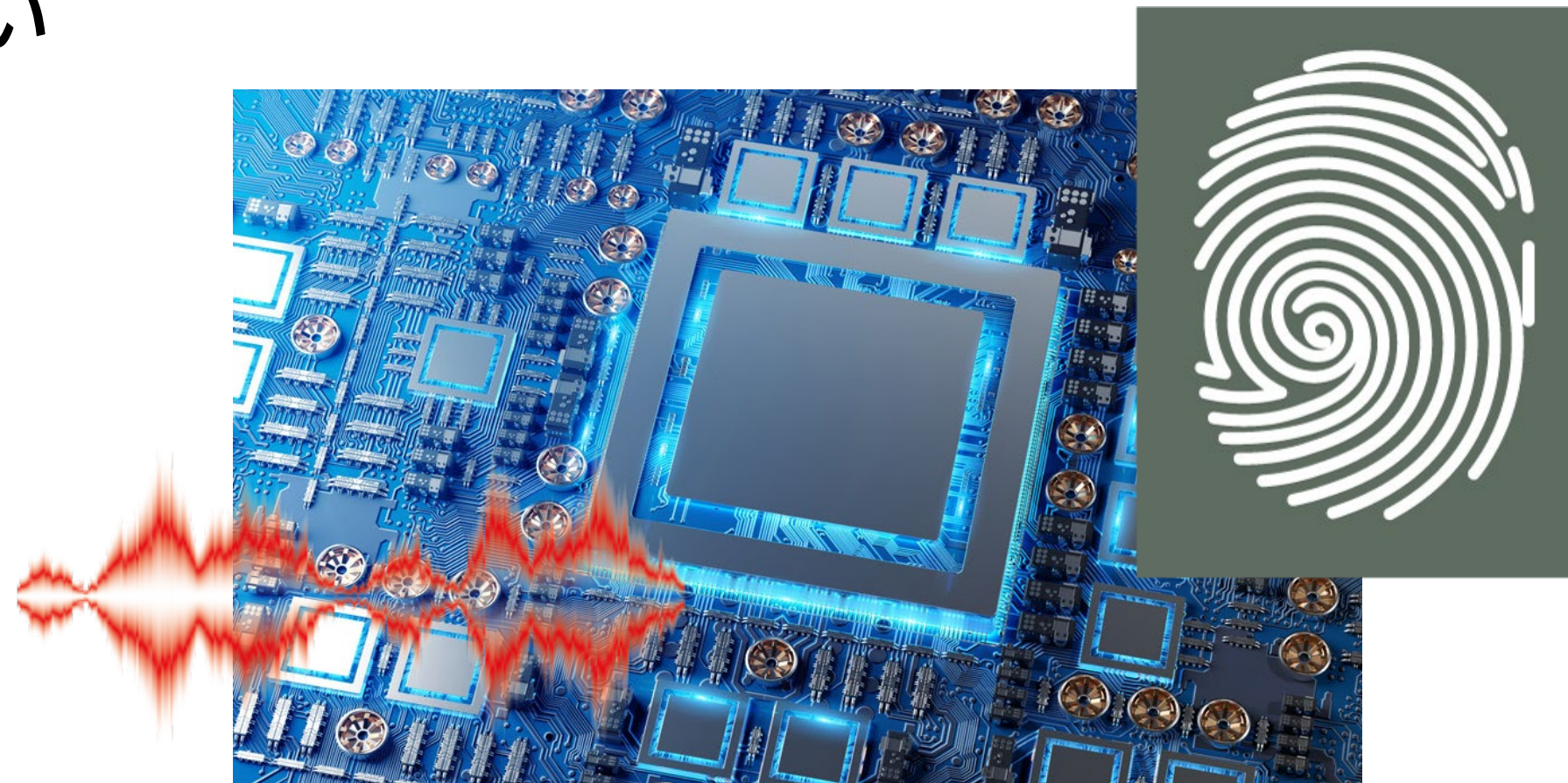
- 暗号鍵の保護や認証、ソフトウェア検証など、セキュリティ機能を提供するための基盤
IoTデバイスでは、そのデバイス固有の秘密情報を保持したハードウェアコンポーネントを指す
- NIST.SP.800-193「Platform Firmware Resiliency Guidelines」:
 - The Root of Trust for Update(RTU)
ファームウェアや重要なデータの更新のための基点
 - The Root of Trust for Detection(RTD)
改ざんなど不具合を検知するための基点
 - The Root of Trust for Recovery(RTRec)
不具合を検知または管理者からの命令による復旧のための基点



■Physically Unclonable Function(PUF)

■ICチップのデジタル指紋

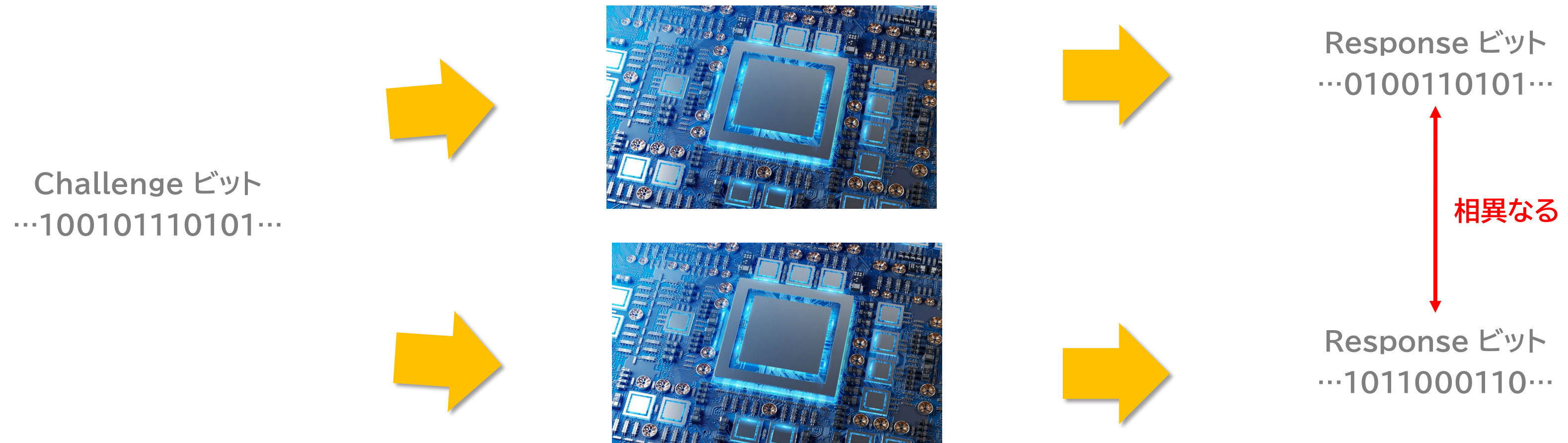
- 紙の模様、電磁記録のムラなど、人為的に制御不能なランダムなパターンを利用した**人工物の指紋**
- LSIの製造ばらつきに応じたチップ固有のデータを生成する**シリコンPUF**が有望視されている
- 回路パターンやデジタルデータはコピーできても、ばらつきをパラメータとするチップ固有の関数はコピーできない



各 LSI の固有な特性を利用

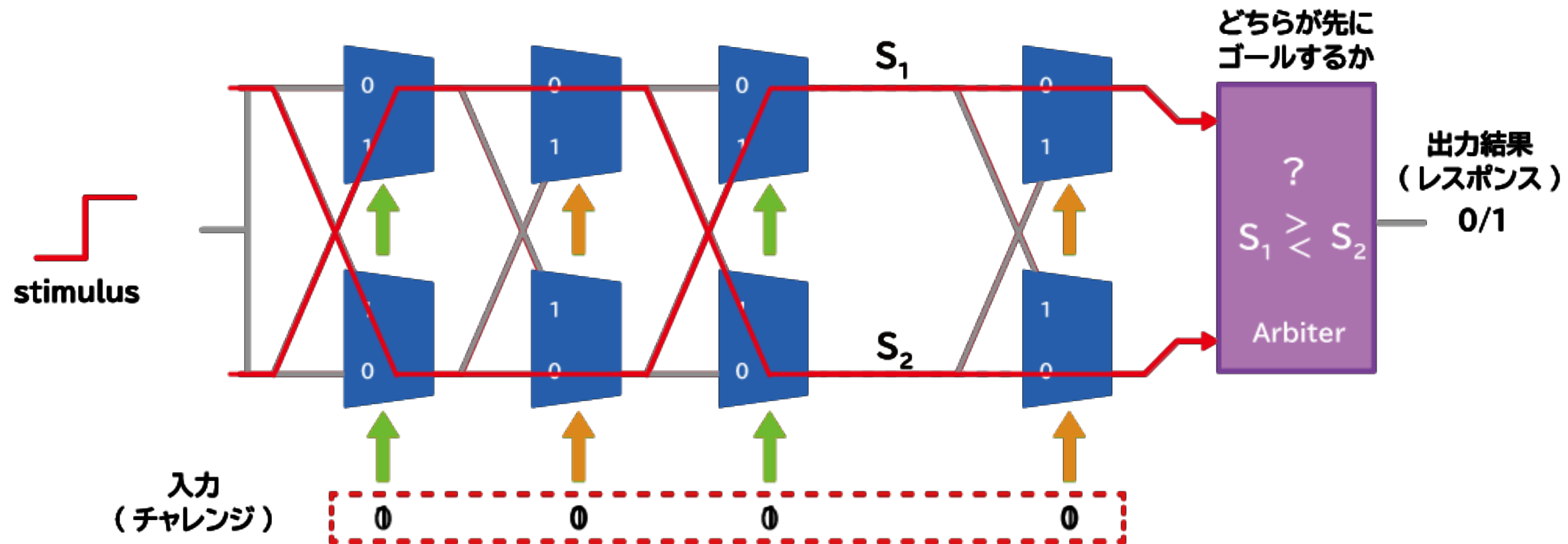
■シリコンPUF

- 同じレイアウトを有する2つの回路であっても、制御不可能なランダムな製造ばらつきによって、物理的なアナログ特性が異なる。
- 個体ごとに異なる入出力応答(Challenge-Response Pair)を返し、入出力の関係は予測不可能
- 2つのPUFは同じChallengeであっても異なるResponseを返す
- 模造品対策、暗号鍵生成、セキュアストレージなどに応用



■Arbiter PUF

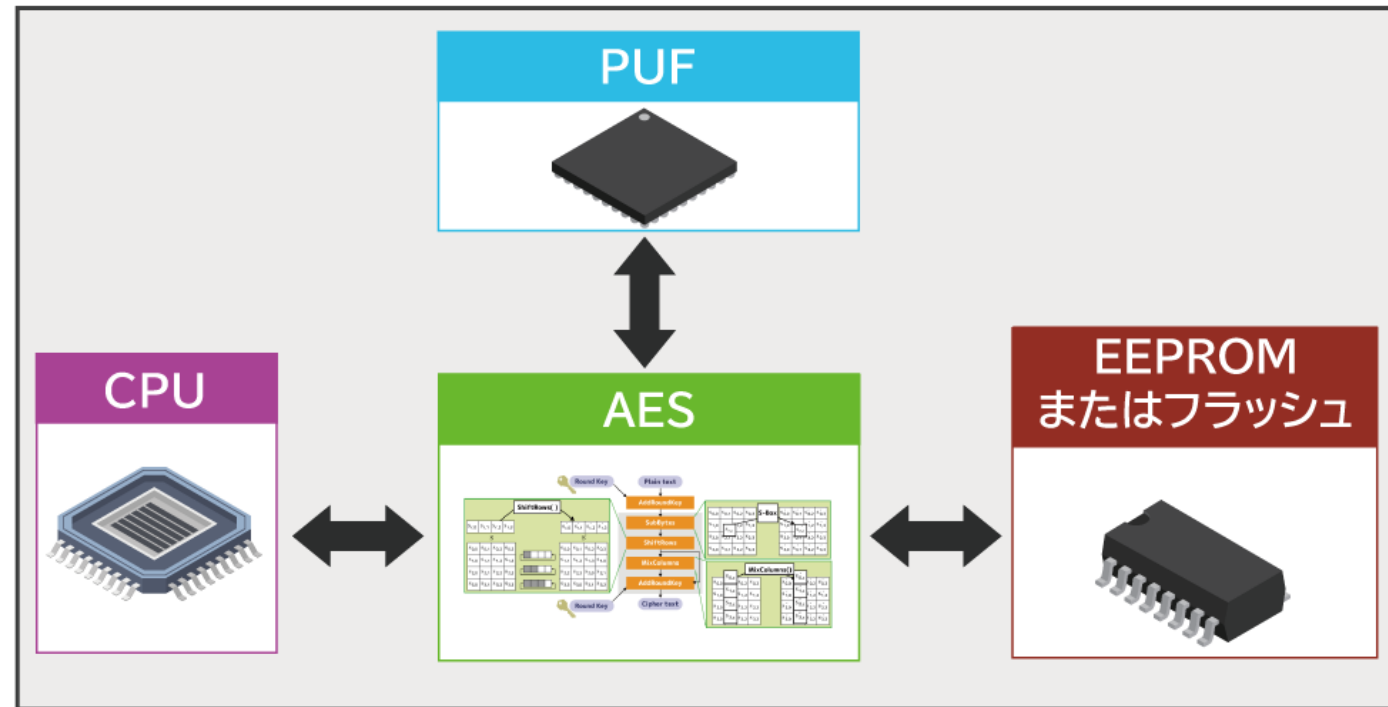
- 2つのスイッチコンポーネントの遅延差を利用した技術
- 上下2つの信号のどちらが先にゴールするか？→出力0 or 1を決定
- 信号経路は製造のばらつきの影響を受けるので遅延差はチップ固有となる(図面上は同じ回路)
- チャレンジNビットに対して、レスポンス1bitが得られる



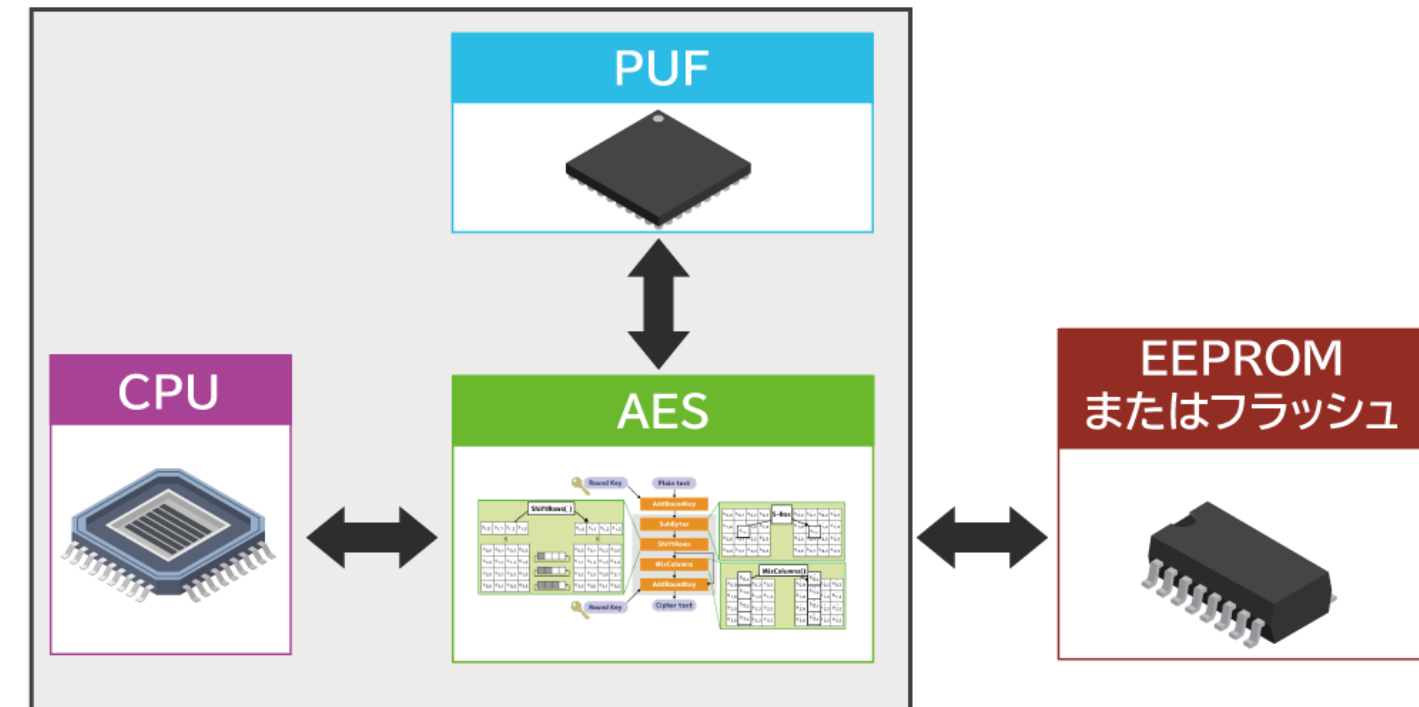
出典: Lee, J.W. et al., "A technique to build a secret key in integrated circuits for identification and authentication applications," VLSI Circ., 2004.

■PUFのアプリケーション例

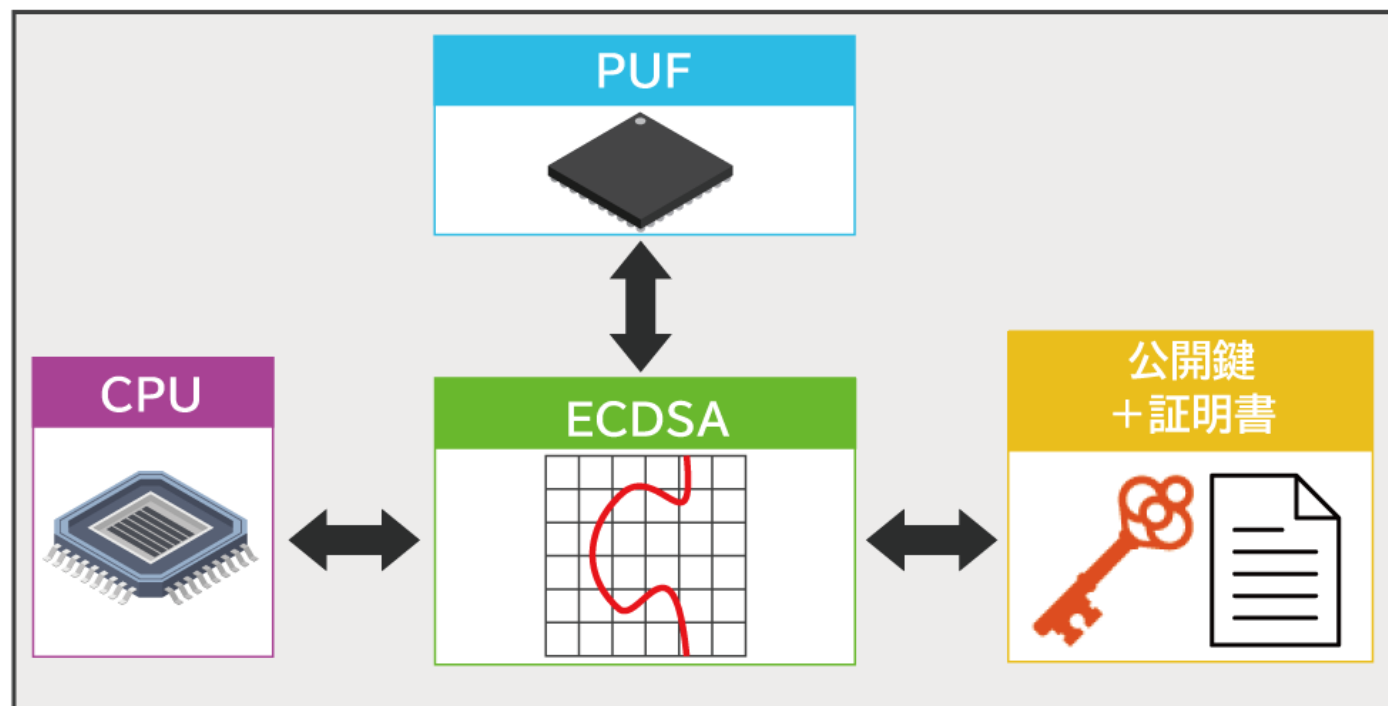
◆内蔵メモリの暗号化



◆外付けメモリの暗号化(セキュアストレージ化)



◆認証鍵の生成



鍵管理から解放される未来が来るかも？

ECDSA: 楕円曲線DSA、デジタル署名アルゴリズムの一種

■CRYPTREC –どの暗号を使うべきか–

- 電子政府推奨暗号の安全性を評価
- 使用に耐えうる暗号技術を選定し
「電子政府推奨暗号」として定めている
- 早晚、危殆化が懸念される暗号は「運用監視リスト」に入る
- これからシステムを構築する場合には、推奨暗号リストから
選択することが望ましい

技術分類		暗号技術
公開鍵暗号	署名	DSA
		ECDSA
		RSA-PSS
		RSASSA-PKCS1-v1_5
	守秘	RSA-OAEP
	鍵共有	DH
ECDH		
共通鍵暗号	64ビットブロック暗号	該当なし
	128ビットブロック暗号	AES
		Camellia
	ストリーム暗号	Kcipher-2
ハッシュ関数		SHA-256
		SHA-384
		SHA-512
暗号利用モード	秘匿モード	CBC
		CFB
		CTR
		OFB
	認証付き秘匿モード	CCM
		GCM
メッセージ認証コード		CMAC
		HMAC
認証暗号		該当なし
エンティティ認証		ISO/IEC9798-2
		ISO/IEC9798-3

